



INDIVIDUAL ASSIGNMENT

ADVANCED CYBER SECURITY

CT114-3-3-VCS

CRITICAL ANALYSIS AND CONTROLLED SIMULATION

2024 CHANGE HEALTHCARE ALPHV/BLACKCAT RANSOMWARE CYBERATTACK

INTAKE CODE: APD3F2601CS(CYB)

DATE ASSIGNED: 8 June 2026

DATE COMPLETED: 20 September 2026

WEIGHTAGE: 50%

NAME: Hemanthrajah A/L N Krishnarajah

TP NUMBER: TP070844

LECTURER / TUTOR: ASSOC. PROF. DR. JALIL BIN MD DESA

Executive Summary

This report discusses the ransomware attack on Change Healthcare in February 2024, and then re-tests a subset of the attack chain in a controlled VMware lab environment. This incident was selected because it illustrates how a relatively mundane vulnerability (stolen credentials are used against a remote-access service that doesn't require multi-factor authentication) can grow into a much bigger problem. The attackers used a legacy Citrix portal to gain access, drill down through the privileges and into Active Directory, exfiltrating protected health information, before using ALPHV/BlackCat ransomware on Windows and ESXi systems. However, the technical compromise soon became a national operational issue due to its ability to be situated in the middle of claims, payment and pharmacy workflows that are utilized throughout the healthcare industry in the United States (U.S. Senate Committee on Finance, 2024).

In Section A, the case is presented to the reader as a cyber threat intelligence challenge and not merely a news article. It distinguishes between facts that are explicitly supported by evidence specific to Change Healthcare and those they are part of the ALPHV/BlackCat tradecraft. The threat actor is believed to be financially motivated ransomware-as-a-service (RaaS) ecosystem affiliate responsible for the successful victim-specific intrusion. MITRE ATT&CK is leveraged as the primary technical framework and the Cyber Kill Chain and Diamond Model are utilized to provide additional context on adversary progression and the connection between adversary, victim, capability, and infrastructure. The separation is crucial because not all BlackCat techniques were in fact performed during this incident.

In Section B, those lessons are put to a controlled VMware test with Kali Linux, a victim Windows 10 and Ubuntu Server with the Wazuh. It replicates certain behaviours - discovery via Nmap, access to valid account on SMB, account discovery, staging of synthetic data, limited TCP transfer and encryption of copied test files, and analyzes the evidence collected in Wazuh, Sysmon, Windows, Wireshark and Volatility. The last few sections use the NIST SP 800-61 Rev. 3, address data-access rights and professional ethics, provide a ransomware playbook, and recommend Zero Trust, MFA, segmentation, monitoring and resilient backups. The exercise is deliberately safe and is not presented as an exact reconstruction of Change Healthcare.

Table of Contents

Executive Summary	2
List of Figures	6
List of Tables	8
1.0 Introduction.....	9
1.1 Scope and Analytical Approach.....	9
1.2 CTI Perspective and Framework Selection.....	10
2.0 Case Study Overview.....	11
2.1 Organizational Context	11
2.2 Attack Background and Key Events	11
2.3 Outcomes and Cyber Threat Intelligence Significance	12
2.4 CTI Classification of the Incident.....	13
3.0 Threat Targets and Impacts.....	13
3.1 Threat Targets	13
3.2 Victim Profile and Target Attractiveness	14
3.3 Technical Impact.....	15
3.4 Operational and Patient-Care Impact.....	15
3.5 Financial Impact.....	16
3.6 Reputational Impact.....	16
3.7 Regulatory and Privacy Impact.....	17
3.8 Critical Impact Evaluation	17
4.0 Cybercrime Profiling and Detection	18
4.1 Threat Actor Attribution and Profile.....	18
4.2 Deductive and Inductive Cybercrime Profiling	19
4.3 Motivation and Objectives.....	19
4.4 Capabilities and Attack Behaviour	19
4.5 Detection of the Change Healthcare Attack.....	20
4.6 Indicators and Evidence Available to Defenders.....	20
5.0 Tactics, Techniques and Procedures (TTPs).....	22
5.1 Complementary CTI Frameworks	22
5.2 ATT&CK Mapping Method	22
5.3 Confirmed and Strongly Supported Change Healthcare TTPs	23
5.4 ALPHV/BlackCat Family-Level TTPs.....	23
5.5 MITRE ATT&CK Navigator Interpretation	26
5.6 Critical TTP Evaluation	27
6.0 Section A Summary and Transition to Section B	27
7.0 Section B: Controlled Simulation Environment and Methodology	28

7.1 Practical Objectives and Scope	28
7.2 Laboratory Architecture	28
7.3 Tools Used in the Lab	30
7.4 Monitoring and Collection Configuration	32
7.5 ATT&CK Selection and Safety Mapping	33
8.0 Controlled Attack Simulation and Detection	34
8.1 Network Service Discovery with Nmap	34
8.2 Valid Account and SMB Access Simulation	37
8.3 Discovery and Atomic Red Team Validation	39
8.4 Synthetic Data Staging	40
8.5 Controlled Exfiltration Simulation	41
8.6 Safe Encryption-Impact Simulation	42
8.7 Laboratory Indicators and Observables	44
8.8 Detection Results Summary	45
9.0 Digital Forensics and Evidence Analysis	46
9.1 Evidence Collection and Integrity	46
9.2 Host and Event Log Correlation	47
9.3 Network Forensics	48
9.4 Memory Forensics with Volatility 3	48
9.5 Reconstructed Incident Timeline	53
9.6 Forensic Interpretation and Limitations	54
10.0 Incident Response Analysis	55
10.1 NIST Incident Response Approach	55
10.2 Preparation	55
10.3 Detection and Analysis	56
10.4 Containment	56
10.5 Eradication	56
10.6 Recovery	57
10.7 Post-Incident Activity	57
10.8 Data Access Rights and Evidence Handling	57
10.9 Ethical Responsibilities of IT Professionals	58
10.10 Relevant Policies and Standards	58
11.0 Cyber Incident Response Playbook and Preventive Controls	59
11.1 Operational Ransomware Playbook	59
11.2 Detection and Escalation Criteria	61
11.3 Zero Trust Application	61
11.4 Preventive and Detective Control Recommendations	61

11.5 Relationship to the Change Healthcare Case	62
12.0 Combined Conclusion.....	63
12.1 Key Findings.....	63
12.2 Assumptions.....	63
12.3 Limitations	64
12.4 Challenges Encountered.....	64
12.5 Recommendations.....	64
12.6 Further Enhancements	65
12.7 Final Conclusion	65
13.0 References.....	66
Appendices.....	69
Appendix A: Custom Wazuh Detection Rules	69
Appendix B: Selected Practical Commands	69
Appendix C: Additional Practical Evidence	70

List of Figures

Figure 1: Evidence-based timeline of the Change Healthcare cyberattack.	12
Figure 2: ATT&CK evidence-layer mapping prepared for MITRE ATT&CK Navigator validation.....	24
Figure 3: Section B laboratory topology and IP addressing.	29
Figure 4: Windows victim network configuration confirming 192.168.6.133 on the VMware NAT segment.	30
Figure 5: Representative tool marks and names used in the practical environment.	31
Figure 6: Core tool stack and the main purpose of each tool in the laboratory.	31
Figure 7: Wazuh central services verified as active on the Ubuntu server.	33
Figure 8: Sysmon64 and the Wazuh agent service running on the Windows victim.	33
Figure 9: Nmap SYN reconnaissance from Kali 192.168.6.129 visible in Wireshark on the Windows victim.	35
Figure 10: Wazuh Rule 100200 identifying a blocked inbound TCP connection from the Kali host.	36
Figure 11: Correlated Wazuh Rule 100201 escalating repeated firewall blocks and mapping the activity to T1046.	36
Figure 12: Deliberate failed SMB authentication followed by successful access to LabShare from Kali.	37
Figure 13: Wazuh view of Event ID 4625 and Logon Type 3 for the deliberately failed labuser SMB authentication.	38
Figure 14: Wazuh view of Event ID 4624 and Logon Type 3 confirming successful network authentication by labuser.	38
Figure 15: Invoke-AtomicRedTeam details for T1087.001 Atomic Test #9 before execution.	39
Figure 16: Atomic Red Team T1087.001-9 execution producing local-account discovery activity.	40
Figure 17: Three synthetic healthcare files created inside C:\LabData for the staging exercise.	41
Figure 18: Healthcare_Test_Archive.zip created from the synthetic files and hashed before transfer.	41
Figure 19: Kali receiving the synthetic archive and verifying its SHA-256 value after transfer.	42
Figure 20: Wireshark capture of the controlled TCP transfer from Windows to Kali on port 9001.	42
Figure 21: Simulation-only AES encryption results showing .locked files, retained key material and a simulation note.	43
Figure 22: Comparison of intact source files in C:\LabData with encrypted simulation copies in C:\LabImpactSim.	44

Figure 23: Exported forensic evidence and SHA-256 integrity values for the collected artefacts.	
.....	47
Figure 24: WinPmem acquisition attempt showing imaging completion followed by cancellation during final handling.....	49
Figure 25: VMware memory image and matching VMSS metadata exposed to Kali through the shared folder.....	49
Figure 26: Volatility 3 windows.info successfully identifying the Windows 10 x64 VMware memory image.	50
Figure 27: Volatility windows.pslist output showing the active Windows process set.....	51
Figure 28: Volatility windows.pstree output used to examine process relationships in memory.	51
Figure 29: Volatility windows.cmdline output showing available process command-line information.....	52
Figure 30: Volatility windows.netscan output showing network objects, including the SMB listener on TCP 445.	53
Figure 31: Volatility filescan search showing no direct recovery of the staged or .locked lab artefacts.	53

List of Tables

Table 1: Threat targets and multi-dimensional impact analysis.	14
Table 2: ALPHV/BlackCat cybercrime profile.	18
Table 3: Public detection evidence and analytical interpretation.	22
Table 4: MITRE ATT&CK mapping for the Change Healthcare / ALPHV BlackCat case. ..	26
Table 5: Section B controlled laboratory architecture.	29
Table 6: Core tools used during the controlled simulation and forensic analysis.	32
Table 7: Controlled simulation mapping to MITRE ATT&CK.	34
Table 8: Laboratory indicators and observables generated during the controlled simulation.	45
Table 9: Detection and evidence summary for the controlled simulation.	46
Table 10: Digital forensic evidence register.	47
Table 11: Reconstructed Section B incident timeline.	54
Table 12: NIST-aligned incident response interpretation of the practical findings.	59
Table 13: Ransomware incident response playbook.	60
Table 14: Recommended preventive and detective controls derived from the case study and practical findings.	62

1.0 Introduction

Ransomware is no longer just a case of files being encrypted and a ransom note appearing afterwards. In many recent incidents, the attacker spends days inside the environment first: accounts are abused, privileges are increased, sensitive data is collected, and only then does the encryption stage begin. That's the sequence that's even more dire in healthcare. An administrative system on paper can be connected directly to prescriptions, insurance checks, claim submission, payments for providers and more than anything else, services and care to the patient on a daily basis. If one of those common systems is compromised, the bad effects rip through much more than just the directly targeted company.

This assignment will be about the case: Cyberattack on Change Healthcare, a UnitedHealth Group subsidiary, February 2024. It is a handy CTI case as there are multiple parts to the intrusion that have been publicly confirmed. The initial compromise was done using compromised credentials, the targeted legacy Citrix service lacked MFA, the attackers then gained access to Active Directory through privilege escalation, protected health information was stolen, and ALPHV/BlackCat ransomware was installed on Windows and ESXi systems (U.S. Senate Committee on Finance, 2024). It wasn't just an IT failure within the organization. Disruption was also felt by hospitals, pharmacies, insurers and physician practices on which Change Healthcare relied.

The report consists of two related sections. In section A, the real event, the actor, the impacts and the TTPs are studied. In section B a small set of those behaviours, in an isolated lab setting, is tested for a small number of students who are able to be protected in those conditions. The primary technical language is MITRE ATT&CK throughout to allow for traceability to the same set of behaviours for the case analysis, simulation and detection rules and forensic evidence.

1.1 Scope and Analytical Approach

The analysis is fact- and evidence-based. UnitedHealth Group filing and incident updates are given priority; U.S. congressional testimony and written responses, as well as HHS Office for Civil Rights, material, the joint CISA/FBI/HHS ALPHV/BlackCat advisory, MITRE ATT&CK, and U.S. Department of Justice reporting are given priority. These surveys are conducted

primarily to demonstrate the downstream impact on hospitals and physician practices, both by the American Hospital Association and the American Medical Association. The combination of this provides the victim's perspective and the industry-wide effect.

One caveat is that public incident reporting doesn't reveal all the details of the technology. For instance, privilege escalation is known to have occurred, but the method of privilege escalation – whether by exploiting an existing privilege or by obtaining a different credential – has not been publicly reported in evidence reviewed. Exfiltration is also confirmed, but the service, protocol or destination that the Change Healthcare affiliate used is not known. Rather than filling those gaps with assumptions, this report leaves them at tactic level or marks the technique as undisclosed. Broader BlackCat behaviours—such as credential theft, tunnelling, remote-access tools, Kerberos abuse, log clearing and recovery inhibition—are discussed separately as actor-associated tradecraft (CISA, FBI, & HHS, 2024).

1.2 CTI Perspective and Framework Selection

Cyber threat intelligence is most useful when technical observations are linked to decisions. For that reason, the report looks at four CTI levels. Strategic intelligence is related to decisions regarding the business and resilience; operational intelligence is related to the ALPHV/BlackCat campaign and affiliate methodology; tactical intelligence is related to behaviours and protection priorities; technical intelligence is related to the more fundamental evidence, including events, IP addresses, process activity, file hashes and network connections (APU, 2026a). When looking at all four levels, the analysis will not be limited to being a list of isolated indicators.

There are three frameworks, but each serve a different purpose. The Cyber Kill Chain can shed light on how the intruder advanced towards its goals. The Diamond Model is useful for relating the adversary, victim, capability and infrastructure. MITRE ATT&CK is a detailed behavioural vocabulary for the mapping of TTPs and future detection. There is no single preferred model, but ATT&CK Navigator was chosen for the assignment, and the other models were utilized to maintain the larger story. (APU, 2026c).

2.0 Case Study Overview

2.1 Organizational Context

Change Healthcare is a big healthcare transaction and technology intermediary. According to Congressional testimony, the company handles approximately 15 billion healthcare transactions annually, and it's accessed about one-third of patient records in the U.S. According to Congressional testimony, the company processes about 15 billion healthcare transactions annually and accesses about one-third of U.S. patient records. It enables providers, insurers and pharmacies to connect with one another for claims and eligibility, for payment and for pharmacy transactions (U.S. Senate Committee on Finance, 2024). This incident rapidly became a problem that affected the entire sector, as a great deal of organizations rely on these shared services.

In 2022, UnitedHealth Group took over Change Healthcare. The Senate Committee on Finance was later told by UHG that applications facing the outside were expected to be compliant with MFA, but the legacy server that was part of the initial compromise had yet to be — U.S. Senate Committee on Finance, 2024. That detail matters. The acquisition is an explanation of how an older system was not included in the newer security baseline but doesn't remove the risk. Technology acquired should be regarded as an active attack surface, a security-governance perspective, until it is completely inventoried, hardened and monitored.

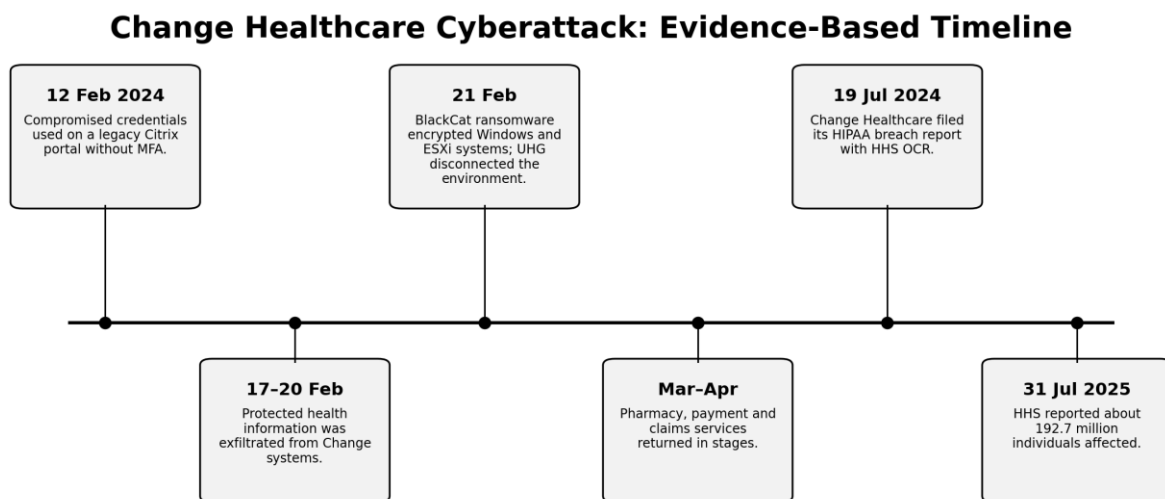
2.2 Attack Background and Key Events

The publicly released timeline begins on 12 February 2024 when bad guys exploited credentials to gain access to a Change Healthcare Citrix portal. The service was externally accessible and did not have MFA. The threat actor stole protected health information from 17 to 20 February. The affiliate used ransomware against the environment on 21 February. UHG has stated that Windows and ESXi had been encrypted and that the attacker managed to escalate their privileges to gain access to the Active Directory server (U.S. Senate Committee on Finance, 2024).

UHG identified and alerted to the destructive phase on 21st February and isolated Change Healthcare systems. Unfortunately, it was a requirement for containments, but it also had the side effect of losing out on some very important transaction services. Putting systems back online was not the only aspect of recovery. To enable systems to be trusted again, UHG reported rotating

credentials and keys, rebuilding data-centre services, and replacing devices, as well as distributing around 11,000 clean devices, and conducting security testing prior to trusting systems (U.S. Senate Committee on Finance, 2024). But if identity infrastructure has been breached, then restoration must be proven to be not only available but also to be intact.

Services returned gradually. The first sector to recover was pharmacy, then payments and medical claims. As of 22 April 2024, the UHG claimed near-normal claim volume and approximately 80% restoration rates for most pharmacies and approximately 80% restoration rates for most UnitedHealth Group (UHG) products (UnitedHealth Group, 2024b). Still, there were administrative delays and cash flows problems for many providers.



Sources: U.S. Senate Committee on Finance (2024); UnitedHealth Group (2024, 2025); HHS OCR (2025).

Figure 1: Evidence-based timeline of the Change Healthcare cyberattack.

2.3 Outcomes and Cyber Threat Intelligence Significance

The first of several CTI lessons: stealing identity may be sufficient to grant access. A public record of a dramatic zero day exploit is not found at the beginning of the intrusion. Rather, credentials were used in the context of a remote-access service that was not multifactored. This is as significant as malware signatures – credential theft, unusual remote logons, device context and identity analytics are equally vital.

Concentration risk is the second lesson. Change Healthcare is linked to a very significant portion of the U.S. healthcare payment and claims system. The attackers disrupted one of the key intermediaries, creating an issue for organisations that they did not directly target. Lastly, the case highlights why today's ransomware is typically a double extortion ransomware. Data was collected prior to encryption of the systems. Availability can be restored by backups, but not a privacy breach. Afterwards, UHG confirmed a \$22 million Bitcoin ransom was paid, but privacy analysis and notification, as well as reputational damage, are ongoing (U.S. Senate Committee on Finance, 2024).

2.4 CTI Classification of the Incident

Strategically, the incident is related to dependency, to the risks to identity, to resilience in operations. Board-level questions involve whether critical third party or acquired systems are fully integrated into security standards, how long essential services can withstand an outage and what is their recovery capacity if there is a loss of trust in the environment. The national disruption and very high response costs make these strategic concerns rather than purely technical ones.

Operational intelligence focuses on the ALPHV/BlackCat ransomware-as-a-service ecosystem, its affiliate model and its approach to high-value victims. Tactical intelligence translates the case into behaviours defenders can hunt for: valid-account abuse, external remote access, privilege changes, sensitive-data access, staging, exfiltration and encryption. Technical intelligence is the evidence that supports those behaviours, such as Windows logon events, process creation, domains, hashes, file changes and outbound network connections. Each level answers a different question, but together they make the intelligence useful.

3.0 Threat Targets and Impacts

3.1 Threat Targets

The attackers targeted several kinds of value at the same time. The first was identity and access. Compromised credentials were used to enter through Citrix, and later access to Active Directory increased the potential reach of the intrusion. The second target was sensitive information. The data review included PHI and PII such as names, addresses, dates of birth, health-plan details, treatment or diagnosis information, provider information and payment-

related data, although the exact data varied by person (U.S. Senate Committee on Finance, 2024). The third target was availability: Windows and ESXi systems supporting Change Healthcare operations were encrypted.

This was an added pressure to the encryption. The organization faced a mission of restoring systems, examining stolen data, informing those affected, complying with regulations and addressing operational repercussions of extended downtime. The attacker, then, established a relationship of "leverage" from two sources: confidentiality and disruption of the service.

Target / Asset	Evidence of Targeting	Impact Interpretation
Identity and remote access	Compromised credentials; Citrix remote-access portal; later Active Directory access.	Valid-looking identities gave the attacker a foothold and later privilege expansion increased control.
Sensitive data	PHI and PII including claims, identity and payment-related information.	Data theft created privacy harm, extortion pressure and large-scale notification work.
Windows and ESXi infrastructure	Ransomware encrypted enterprise systems.	Availability was lost and the environment required rebuilding, validation and phased restoration.
Claims, payment and pharmacy services	Transaction services and dependent workflows.	The outage spread to hospitals, physician practices, pharmacies, payers and patients.
Trust and compliance	Security controls, acquisition integration and healthcare data stewardship.	The missing MFA control and size of the breach increased regulatory and reputational pressure.

Table 1: Threat targets and multi-dimensional impact analysis.

3.2 Victim Profile and Target Attractiveness

The victim profiles outlined below help shed light on why Change Healthcare was an appealing ransomware target. The organization facilitates time-critical transactions, manages and

protects precious health data, and connects numerous providers, payers and pharmacies. A prolonged power outage would not only put strain on the company, but also on customers awaiting claims and payments. This provides a powerful financial incentive for an extortion organization (APU, 2026b).

The case demonstrates the value/opportunity relationship as well. Access to the same data via a legacy remote-access service that was not MFA enabled made it much easier to leverage stolen credentials. Inside, the need for Active Directory, sensitive data repositories and sensitive transaction systems meant that more privilege would result in far greater impact. This victim profile clearly highlights practical defensive priorities, such as strong external authentication, rapid integration of acquired systems, least privilege, segmentation and monitoring around high-value data and identity services.

3.3 Technical Impact

The attack impacted availability and trust. Ransomware was found to compromise Windows and ESXi infrastructure, and privileged identity paths were compromised leaving credentials and keys vulnerable. To minimize the risk of a breach, UHG rotated credentials and keys, rebuilt services and validated systems prior to returning them to production (U.S. Senate Committee on Finance, 2024). The difference between a failed server recovery and an environment integrity questionable recovery.

The answer is further testament to the value of segmentation. UHG has disconnected all connectivity to Change Healthcare since the ransomware attack was discovered, helping to secure the broader UnitedHealth environment. Meanwhile, shutting those systems down caused significant service problems. Having both sides to good resilience is essential, quickly isolating compromised systems and continuing essential business processes using tested alternatives.

3.4 Operational and Patient-Care Impact

Those operational impacts were particularly broad due to the support of shared healthcare workflows by Change Healthcare. Claims to Pharmacy, claims to medical were stopped, eligibility checks were stopped and payment processes were stopped. Until services were restored, UHG implemented temporary fixes and provided financial assistance (UnitedHealth

Group, 2024b). The incident did not prevent all of the providers from providing care for patients, however, treatment administrative systems grew cumbersome and difficult to use.

Independent surveys show that the disruption was felt outside UHG. The American Hospital Association conducted a survey of almost 1,000 hospitals, and found direct effects on patient care and significant financial issues, and the American Medical Association reported claim and payment issues in physician practices (AMA, 2024; AHA, 2024). This is significant because it indicates that the impact wasn't limited to the encrypted servers. It's got into organizations where there's been no breach of their networks.

3.5 Financial Impact

There are several separate categories that demonstrate the financial effect. In UnitedHealth's direct response segment, about \$2.2 billion in direct response costs were reported for 2024 and an estimated \$867 million in business-disruption impact in United's Optum Insight segment. The company also acknowledged that it paid \$22 million in ransom (UnitedHealth Group, 2025; U.S. Senate Committee on Finance, 2024). These cannot be summed up just as the accounting categories are different and overlap in certain areas.

A more general liquidity issue was also a problem. At the end of year 2024, UHG had given over \$9 billion in interest-free loan to care providers impacted by payment flow interruptions (UnitedHealth Group, 2025). This risk of dependency is stark when claims infrastructure fails: Smaller providers can find themselves with payroll and cash-flow issues, even if they are not the intended target of the cyberattack.

3.6 Reputational Impact

While more difficult to quantify, the absence of the MFA control was a significant issue facing the public. The congressional spotlight was on the lack of MFA for the compromised external server, even though UHG had previously anticipated that external-facing applications would implement MFA (U.S. House Committee on Energy and Commerce, 2024). An avoidable control gap incident will cause different losses to confidence as an incident of an unknown vulnerability would do since one of the questions stakeholders will ask themselves is whether the incident could have been prevented with a simple safeguard.

The addition of health privacy data added to the loss of trust. Patients and healthcare stakeholders are expecting that information and data regarding their health and identities will be treated with great care. That confidence can't be restored with service restoration. The reputation recovery process includes clear notification, visibility and progressive resilience.

3.7 Regulatory and Privacy Impact

The main regulatory issues relate to HIPAA privacy, security and breach-notification requirements. HHS OCR investigated the incident and a breach report was filed by Change Healthcare on 19 July 2024. Notification obligations were also complex and there were a significant number of customers (HHS, 2025) due to the fact that Change Healthcare is a business associate and intermediary for many healthcare organizations.

As the data review continued the number of affected people was increasing. HHS later reported that some 192.7 million individuals were affected (HHS, 2025). The evolving figure reveals a frequent issue in major breaches: organizations might be required to share risk and adhere to legal obligations before all the record-level determinations are completed. In that process, it is critical to have good data inventory, control of data retention and data ownership tracking.

3.8 Critical Impact Evaluation

The most significant lesson and impact is that dependency centrality is important as much as the number of infected endpoints. One major intermediary was compromised, causing numerous other organizations down the chain to be disturbed. A "traditional" impact model that would only take into account the number of encrypted hosts would seriously underestimate such an incident. Transaction volume, concentration and the availability of substitutes have to be included in cyber-risk planning.

Mutual support also occurred in the areas of confidentiality and availability. While backups might aid with encryption, they would not be able to undo the exfiltration of PHI. The payment of a ransom wouldn't eradicate notification requirements or ensure that any stolen information had vanished. The case promotes a multi-layered strategy with a focus on identity security, data protection, segmentation, monitoring, resilient backups and prepared incident response.

4.0 Cybercrime Profiling and Detection

4.1 Threat Actor Attribution and Profile

The ALPHV/BlackCat ecosystem was responsible for the ransomware deployment, via an affiliate. This is the key statement. BlackCat is not only a ransomware family, but also a ransomware-as-a-service (RaaS) scheme. Core operators keep the infrastructure and malware, and affiliates pick victims, make the intrusion, and then split the ransom revenue with the service operators (DOJ, 2023). The name of the malware alone does not provide the specific name of the people who broke into Change Healthcare.

The actor has been described as a financially-motivated and organized group of cyber-criminals who has high technical and extortion skills. According to DOJ, BlackCat has attacked over a thousand victims globally. Operating model is based on stealing data, encrypting it and pressuring to publish the stolen data. That pattern fits the Change Healthcare evidence closely because data was removed before the ransomware stage and a ransom was later paid.

Profile Element	Assessment
Actor / ecosystem	ALPHV / BlackCat / Noberus ransomware-as-a-service ecosystem, with an affiliate conducting the victim-specific intrusion.
Primary motivation	Financial gain through extortion and ransom payment.
Objectives	Maintain access, increase privilege, locate valuable information, exfiltrate data and create operational pressure through encryption.
Capability level	High. The ecosystem supports Windows, Linux and VMware/ESXi encryption and uses credential, remote-access and post-exploitation tooling.
Operational model	Core developers maintain malware and infrastructure; affiliates conduct intrusions and share ransom proceeds.
Attribution limitation	Public evidence identifies the ecosystem and an affiliate but not the exact affiliate identity or every tool used in this victim network.

Table 2: ALPHV/BlackCat cybercrime profile.

4.2 Deductive and Inductive Cybercrime Profiling

Deductive profiling starts with the evidence from this specific incident. Here, the confirmed use of compromised credentials, later privilege escalation, pre-encryption data theft, Windows/ESXi ransomware and a ransom payment support a clear conclusion: the operators were technically capable and financially motivated, and they were trying to create several kinds of leverage at once. That conclusion comes from the Change Healthcare evidence itself rather than from assumptions about every BlackCat affiliate (APU, 2026b).

Inductive profiling works in the other direction. Repeated behaviours seen across BlackCat activity are used to form hunting hypotheses for what defenders might also expect to find. CISA, FBI, HHS, DOJ and MITRE describe an affiliate-driven ecosystem that uses credential theft, legitimate remote tools, post-exploitation frameworks, data exfiltration and encryption. Those patterns are useful for investigation, but they remain hypotheses until victim-specific evidence supports them. Keeping the two types of reasoning separate makes the profile more defensible.

4.3 Motivation and Objectives

The primary motivation was for financial profit. Change Healthcare had multiple sources of pressure: national important services, sensitive health information, large corporate owner and significant reputational exposure. Monetization was not only a theoretical aim, but it also happened with the confirmed \$22 million ransom payment (U.S. Senate Committee on Finance, 2024).

The middle goals were more general, such as for running ransomware. The affiliate had to access, elevate privileges, learn about the environment, find helpful systems and information, stage data, get it out of the environment and finally cause enough operational disruption to add to the pressure. It's much more valuable if defenders are actively searching for those target objectives rather than waiting for a ransomware executable to emerge.

4.4 Capabilities and Attack Behaviour

BlackCat affiliates engage in social engineering, use compromised accounts, remote-access software, tunnelling tools, Cobalt Strike, Brute Ratel C4, Evilginx2, credential theft, cloud services to move data, log clearing and ransomware deployment, the advisory reads. The

malware can impact Windows, Linux and VMware environments (CISA, FBI, & HHS, 2024; MITRE ATT&CK, 2025). It is not easily detectable by simple signatures because of the offensive tools and the legitimate administrative software.

That's only a segment of that capacity set that is backed up by Change Healthcare-specific evidence. Those compromised credentials facilitated access, privilege escalation then transferred to Active Directory, PHI was exfiltrated and ransomware then impacted Windows systems and ESXi. The period of time (9 days) between first access and the destructive stage indicates that this was not an automatic infection; it was a campaign of work done by hand on the keyboard. That dwell time resulted in the opportunity to detect earlier.

4.5 Detection of the Change Healthcare Attack

The ransomware attack was picked up by Public reporting as it became visible on 21 February and UHG then isolated Change Healthcare from the rest of the environment. The two instances of credentialed access (on 12 February and during the data-exfiltration period, 17–20 February) are not public details that affected containment first (U.S. Senate Committee on Finance, 2024). The timeline indicates a timing issue in detection, as the impact phase was detected but the previous behaviour was not prevented in time.

An invalid username and password used via a valid Citrix interface may appear normal, without additional context. These indicators would include a new device, unusual source network, unexpected logon time, privilege changes, abnormal access to Active Directory, and/or a rapid access to sensitive repositories or unusually large outbound transfer. If there were UHG alerts, they are reasonable inferences (but not proof of) from the known sequence.

4.6 Indicators and Evidence Available to Defenders

Behavioural evidence for this case is more useful than assuming that all the BlackCat campaign IOCs were at Change Healthcare. Specific elements are the capability to access Citrix via credentialed access on February 12, the exfiltration window on February 17-20, ransomware deployment on February 21, access to Active Directory after privilege escalation, and encryption of Windows and ESXi. These behaviors are still valid in the event that the attacker switches out their IP address, domain or file hash.

CISA also publishes BlackCat campaign indicators such as domains, IP addresses, remote-access infrastructure and file hashes. They can be useful for enrichment and threat hunting but are not necessarily Change Healthcare specific unless they can be traced back to this incident by an independent source. Case evidence and campaign intelligence have been kept separate throughout this report.

Indicator / Event	Evidence Status	Why It Matters	Detection Source
12 Feb 2024: credentialed Citrix access	Confirmed case evidence	A valid-looking remote session can bypass basic password checks; identity context and MFA matter.	Authentication logs, source network, device fingerprint, conditional-access analytics.
Privilege escalation and Active Directory access	Confirmed case evidence	Shows movement from remote access towards control of enterprise identity infrastructure.	Windows/AD audit logs, privileged-group changes, unusual domain-controller access.
17–20 Feb: PHI exfiltration	Confirmed case evidence	Data theft occurred before encryption, leaving a detection window.	Proxy/firewall logs, DLP, outbound-volume monitoring, archive creation and sensitive-file access.
21 Feb: Windows and ESXi ransomware	Confirmed case evidence	High-confidence impact-stage activity requiring immediate containment.	EDR, hypervisor logs, mass file-change telemetry and recovery-inhibition events.

Indicator / Event	Evidence Status	Why It Matters	Detection Source
CISA campaign IOCs	ALPHV/BlackCat campaign-level intelligence	Useful for enrichment, but not automatically Change Healthcare-specific.	SIEM threat- intelligence lookup, DNS/firewall logs and EDR IOC matching.

Table 3: Public detection evidence and analytical interpretation.

5.0 Tactics, Techniques and Procedures (TTPs)

5.1 Complementary CTI Frameworks

A simple attack-progression view is provided by the Cyber Kill Chain. No reconstruction of the reconnaissance and weaponisation/delivery are invented here, as they are not fully disclosed in Public Change Healthcare reporting. The credentialed remote access phase is the first step in this sequence; then comes privilege escalation, data theft, and impact from ransomware. This is useful for asking where the organisation could have interrupted the attack before the final objective.

The Diamond Model adds a relationship view. The adversary is the ALPHV/BlackCat ecosystem and its unidentified affiliate; the victim is Change Healthcare and, indirectly, the healthcare organisations depending on it; the capability includes valid-account abuse, post-exploitation activity, data theft and ransomware; and the infrastructure includes the external Citrix pathway plus attacker infrastructure that has not been fully disclosed. MITRE ATT&CK is then used for the detailed technical mapping because it supports direct links between behaviours, telemetry and detection engineering (APU, 2026c).

5.2 ATT&CK Mapping Method

The ATT&CK mapping uses three evidence labels. 'Confirmed' means the activity is directly supported by public Change Healthcare evidence. 'Strongly supported' means the technique is a conservative interpretation of a confirmed fact—for example, using an externally accessible Citrix portal fits External Remote Services. 'Actor-associated' means the behaviour is documented for ALPHV/BlackCat generally but has not been confirmed in this victim network.

The purpose of these labels is to stop the ATT&CK matrix from looking more certain than the evidence really is.

This method also leads Section B. The simulation is based on selected behaviours that can safely be simulated, and that provide useful telemetry. Actor associated techniques are only used when they help to validate the control, and are explicitly identified as simulation options rather than claims about past events of Change Healthcare.

5.3 Confirmed and Strongly Supported Change Healthcare TTPs

Initial Access maps directly to Valid Accounts (T1078) because credentials used to access the system were found to be compromised. External Remote Services (T1133) is strongly supported as part of the process of using those credentials by accessing an externally accessible Citrix service. The MFA control is not a standalone technique, but it definitely provided a lot of leeway in exploiting the valid-account pathway. At the tactic level, privilege escalation is confirmed, due to UHG stating that the attacker had escalated their privileges and gained access to Active Directory.

Exfiltration is also confirmed only at the tactic level because the reviewed sources do not identify the exact transfer channel used in the real incident. The final impact stage maps clearly to Data Encrypted for Impact (T1486), as both Windows and ESXi systems were encrypted. This technique is also documented by MITRE as part of BlackCat behaviour.

5.4 ALPHV/BlackCat Family-Level TTPs

The wider BlackCat ecosystem has a broader ATT&CK footprint than the victim-specific public record. The joint advisory describes Phishing for Information (T1598), Compromise Accounts (T1586), Credentials from Password Stores (T1555), Adversary-in-the-Middle (T1557) using Evilginx2, and Steal or Forge Kerberos Tickets (T1558). It also describes legitimate remote-access and tunnelling tools and the use of cloud services for moving data. MITRE documents BlackCat behaviours including Domain Account Discovery (T1087.002), Network Share Discovery (T1135), Lateral Tool Transfer (T1570), Clear Windows Event Logs (T1070.001), Inhibit System Recovery (T1490) and Data Encrypted for Impact (T1486) (CISA, FBI, & HHS, 2024; MITRE ATT&CK, 2025).

These behaviours are valuable as hunting ideas. Once a defender confirms suspicious credential use, the next question should not be only 'do we have a ransomware hash?'. It should also be whether the account has enumerated the domain, accessed unusual shares, launched remote-management tools, created archives, moved data to external services or changed recovery settings. The report hunts value without claiming that every one of those actions happened at Change Healthcare.

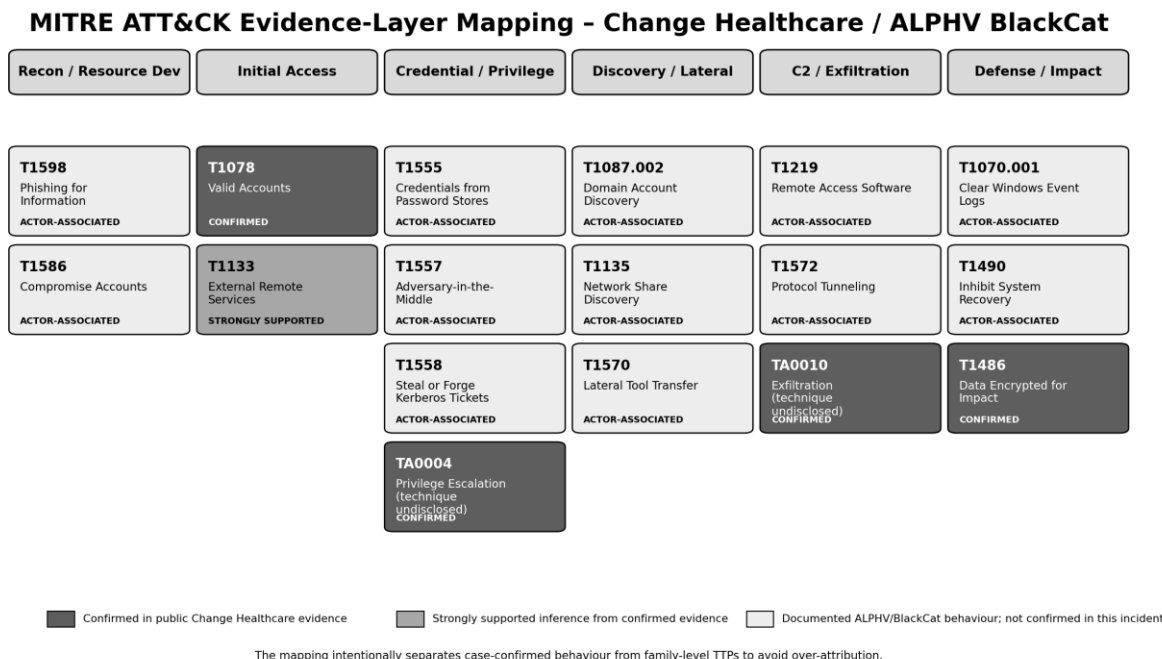


Figure 2: ATT&CK evidence-layer mapping prepared for MITRE ATT&CK Navigator validation.

Evidence Status	Tactic	ATT&CK ID	Technique	Case / Threat Interpretation
Confirmed	Initial Access	T1078	Valid Accounts	Compromised credentials were used to access Change Healthcare.
Strongly supported	Initial Access	T1133	External Remote Services	The credentials were used through an externally accessible Citrix portal.

Evidence Status	Tactic	ATT&CK ID	Technique	Case / Threat Interpretation
Confirmed	Privilege Escalation	TA0004	Technique not publicly disclosed	UHG confirmed privilege escalation before Active Directory access; the exact method is not public.
Confirmed	Exfiltration	TA0010	Technique not publicly disclosed	PHI was exfiltrated from 17–20 February; the exact channel is not public.
Confirmed	Impact	T1486	Data Encrypted for Impact	Ransomware encrypted Windows and ESXi systems on 21 February.
Actor-associated	Reconnaissance	T1598	Phishing for Information	CISA documents BlackCat affiliates posing as IT/helpdesk staff to obtain credentials.
Actor-associated	Resource Development	T1586	Compromise Accounts	Compromised-account use is documented across BlackCat operations.
Actor-associated	Credential Access	T1555	Credentials from Password Stores	BlackCat affiliates obtain passwords from endpoints and domain infrastructure.
Actor-associated	Credential Access	T1557	Adversary-in-the-Middle	Evilginx2 has been used to capture credentials, MFA material and session cookies.

Evidence Status	Tactic	ATT&CK ID	Technique	Case / Threat Interpretation
Actor-associated	Credential Access	T1558	Steal or Forge Kerberos Tickets	Kerberos token generation is documented for domain access.
Actor-associated	Command and Control	T1219 / T1572	Remote Access Software / Protocol Tunnelling	Legitimate remote tools and tunnelling utilities are documented in BlackCat operations.
Actor-associated	Discovery	T1087.002 / T1135	Domain Account / Network Share Discovery	MITRE documents account and share enumeration.
Actor-associated	Lateral Movement	T1570	Lateral Tool Transfer	BlackCat has replicated tooling to connected systems.
Actor-associated	Defense Evasion	T1070.001	Clear Windows Event Logs	BlackCat can clear Windows event logs.
Actor-associated	Impact	T1490	Inhibit System Recovery	BlackCat can remove shadow copies or change recovery settings.

Table 4: MITRE ATT&CK mapping for the Change Healthcare / ALPHV BlackCat case.

5.5 MITRE ATT&CK Navigator Interpretation

The actual case-confirmed path is quite a small one: credentials and remote access, privilege escalation, exfiltration and the resulting confidentiality pressure and finally the operational impact from encryption. The space in the center is not a hindrance, but rather a necessity. They identify where further evidence would be required for a more specific technique claim to be made.

The actor associated layer expands the path they know is forfeited defense. Once the intrusion is suspected to be related to BlackCat, credentials stores, Kerberos activity, remote-management tools, tunnelling, share discovery, lateral transfer, log clearing and recovery inhibition are reasonable targets to search for. The Navigator view, then, is not a means to make historical claims, but rather a means to collect and detect.

5.6 Critical TTP Evaluation

In this instance, the most significant TTP may be the most innocuous: Valid Accounts. The attackers only got to the visible crisis because stolen credentials enabled them to gain access to a valuable external service. That brings the focus for defence to phishing-resistant MFA, conditional access, device trust and privileged-access management and behavioural monitoring. A high risk remote session should not be considered legitimate based on a correct username and password combination.

The second big lesson is that the data theft and encryption are two different things. Prior to the effects of the ransomware, PHI was exfiltrated. This implies that you can't just get around all the problems with backups. In addition, detection engineering should focus on unique archive creation patterns, access to sensitive files and the transfer of archive files before encryption. Last but not least, ATT&CK mapping should be of a disciplinary nature. The smaller the mapping, the better it has to be supported and the more useful it can be if it's not quietly turning possibilities into facts in a larger matrix.

6.0 Section A Summary and Transition to Section B

The title of the story is obvious in section A. A legacy Citrix service without MFA was compromised with compromised credentials. The actor then increased permissions, logged in to Active Directory, stole the PHI, and installed ALPHV/BlackCat ransomware on Windows and ESXi machines. It cascaded through claims, pharmacy and payment services as Change Healthcare is a very well networked intermediary. The event had technical, financial, privacy, regulatory and reputational implications.

The practical activities in part (b) do not seek to replicate the actual attack as in part (a) as several technical aspects are not public, and using a real ransomware would not be safe. For example, the lab replicates the following behaviours that can be tested responsibly:

reconnaissance, valid account access, discovery, staging, controlled outbound transfer and file-encryption impact. The primary objective is to observe what evidence is generated at each stage and if Wazuh, Sysmon, Windows logs, Wireshark and Volatility can be used to recreate the chain.

7.0 Section B: Controlled Simulation Environment and Methodology

7.1 Practical Objectives and Scope

The aim of the practical is to make the Section A threat analysis tangible in terms of security incidents. The lab is not intended to validate that the same commands were used at Change Healthcare. Rather, it evaluates if behaviors from the same attack lifecycle can be safely generated, and then detected. This way the exercise is still useful, but not in the realm of deployment of real malware or unsupported historical reconstruction.

The traffic was limited to VMware NAT virtual machines on 192.168.6.0/24. There was no real organization, public IP address or production system targeted. The synthesis of healthcare-like files was done during the staging and transfer tests only, and the encryption exercise was carried out on copies of the files located in a separate simulation folder. Original synthetic files preserved to allow for impact stage to be demonstrated without loss of data.

7.2 Laboratory Architecture

Three main virtual machines were used on the testbed. The attacker was Kali Linux at address: 192.168.6.129 and the analysis workstation was Kali Linux at address: 192.168.6.127. Wazuh manager, indexer, dashboard and Filebeat components were installed on Ubuntu Server 22.04.5 (192.168.6.132). The victim endpoint was Windows 10 on address 192.168.6.133, and was hosting Wazuh agent, Sysmon, Windows Firewall auditing, PowerShell and Wireshark. The communication between the systems was enabled using VMware NAT, which enabled the exercise without being connected to real external targets.

Section B Laboratory Topology (VMware NAT 192.168.6.0/24)

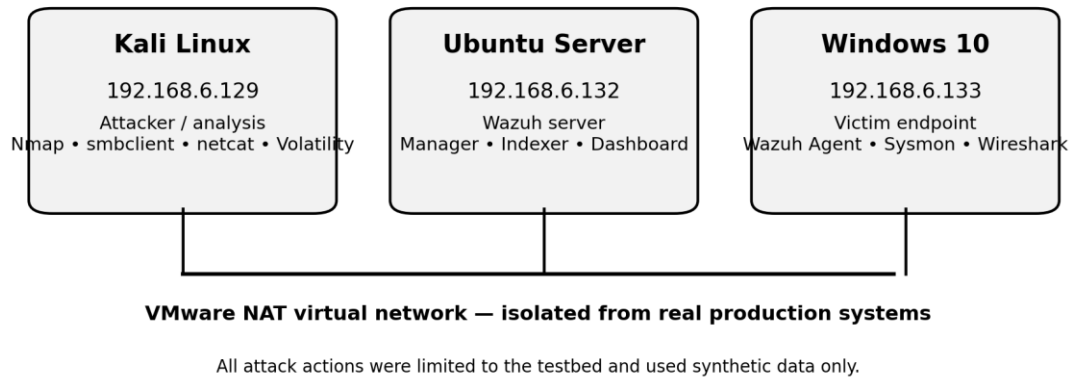


Figure 3: Section B laboratory topology and IP addressing.

Component	IP Address	Hostname	Role / Tooling
Kali Linux attacker	192.168.6.129	HemanthKali	Nmap, smbclient, netcat, packet analysis and Volatility 3
Wazuh server	192.168.6.132	wazuh-server	Ubuntu Server 22.04.5; Wazuh manager, indexer, dashboard and Filebeat
Windows 10 victim	192.168.6.133	DESKTOP-MDQB9LL	Wazuh agent, Sysmon, Firewall auditing, PowerShell and Wireshark
VMware NAT network	192.168.6.0/24	Virtual network	Isolated communication between the three laboratory systems

Table 5: Section B controlled laboratory architecture.

```
C:\Users\heman>ipconfig

Windows IP Configuration

Ethernet adapter Ethernet0:

    Connection-specific DNS Suffix  . : localdomain
    Link-local IPv6 Address . . . . . : fe80::4817:286:3ba6:ba87%6
    IPv4 Address. . . . . : 192.168.6.133
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.6.2
```

Figure 4: Windows victim network configuration confirming 192.168.6.133 on the VMware NAT segment.

7.3 Tools Used in the Lab

The practical is designed with multiple tools since none of them demonstrate the entire incident. The Windows agent sends endpoint events to the central SIEM/XDR platform, Wazuh. The platform features endpoint agents, a server, indexer and dashboard to achieve log analysis, threat detection and security monitoring (Wazuh, 2026). When standard Windows logs aren't sufficiently detailed, Sysmon includes a wealth of additional Windows telemetry data, including process creation and network connection details (Microsoft, 2026).

The controlled reconnaissance stage is performed with the help of Nmap. It is a network discovery and security-auditing tool that can detect hosts and services that are reachable and filtering behavior (Nmap Project, 2026). It is used in conjunction with Wireshark to capture and analyze packets on the fly, which independently verifies what packets do actually pass over the network (Wireshark Foundation, 2026). Kali Linux gives the environment for the attacker while VMware Workstation offers the isolated testbed for the virtual machine.

Atomic Red Team is leveraged only for safe ATT&CK aligned control validation. The project delivers small, focused tests that defenders can perform to determine if anticipated telemetry is generated (Red Canary, 2026). Later, Volatility 3 will be used for memory analysis. It can retrieve artifacts from RAM without needing to be a part of the running system, making it valuable for post-mortems on processes, command lines and network objects (Volatility Foundation, 2025).

Representative Tool Marks and Names Used in the Lab

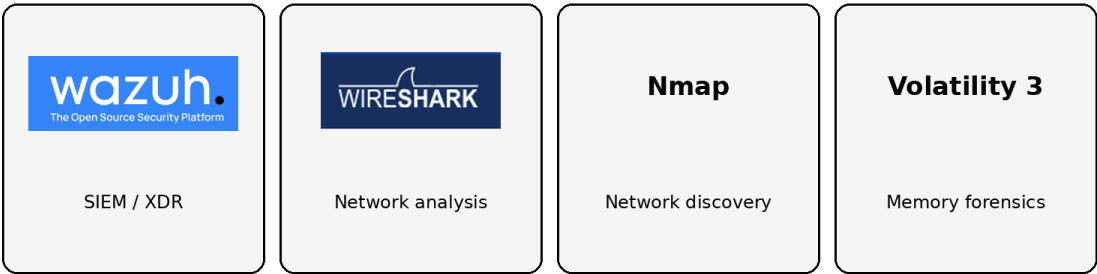
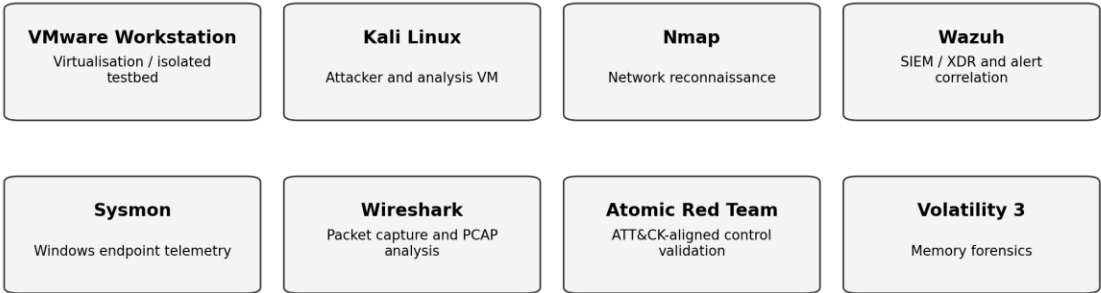


Figure 5: Representative tool marks and names used in the practical environment.

Core Tool Stack Used in the Practical Lab



Tool names are shown as a compact overview; screenshots in later sections provide the primary practical evidence.

Figure 6: Core tool stack and the main purpose of each tool in the laboratory.

Tool	Main Role in this Assignment	Why It Was Used
VMware Workstation	Virtualisation	Kept attacker, victim and monitoring systems in an isolated testbed.
Kali Linux	Attacker / analysis VM	Provided Nmap, smbclient, netcat and Volatility analysis environment.
Wazuh	SIEM / XDR	Centralised alerts, Windows events and custom correlation rules.

Tool	Main Role in this Assignment	Why It Was Used
Sysmon	Endpoint telemetry	Recorded detailed process and selected file/network behaviour on Windows.
Wireshark	Network forensics	Captured SYN scanning and the controlled TCP transfer in PCAP form.
Nmap	Network reconnaissance	Generated the controlled service-discovery behaviour mapped to T1046.
Atomic Red Team	ATT&CK emulation	Produced a known T1087.001 local-account discovery test for control validation.
Volatility 3	Memory forensics	Analysed the VMware memory image for system, process and network state.

Table 6: Core tools used during the controlled simulation and forensic analysis.

7.4 Monitoring and Collection Configuration

The all-in-one deployment of Wazuh 4.14.7 was performed in an Ubuntu Server. Requirements were checked before testing such as checking the list of services (manager, indexer, dashboard and Filebeat services) to ensure that if no alert were found, it was not solely due to a service being stopped. The Windows endpoint has been registered as agent 001. Sysmon was installed on the victim and tuned to collect process creation, selected network activity, targeted file creation, Run/RunOnce registry changes and access to LSASS. It was kept rather selective as an earlier, wide ProcessAccess rule introduced a lot of benign Event ID 10 noise.

```
09/09/2026 09:48:41 INFO: Installation finished.
hemanth@wazuh-server:~$ sudo systemctl is-active wazuh-manager
[sudo] password for hemanth:
active
hemanth@wazuh-server:~$ sudo systemctl is-active wazuh-indexer
active
hemanth@wazuh-server:~$ sudo systemctl is-active wazuh-dashboard
active
hemanth@wazuh-server:~$ sudo systemctl is-active filebeat
active
hemanth@wazuh-server:~$ _
```

Figure 7: Wazuh central services verified as active on the Ubuntu server.

```
PS C:\LabTools\Sysmon> Restart-Service WazuhSvc
PS C:\LabTools\Sysmon> Get-Service Sysmon64,WazuhSvc
```

Status	Name	DisplayName
-----	----	-----
Running	Sysmon64	Sysmon64
Running	WazuhSvc	Wazuh

Figure 8: Sysmon64 and the Wazuh agent service running on the Windows victim.

Also, the auditing of Windows Firewall was activated. Event ID 5157 was added to Wazuh for blocking connections to be correlated during Nmap testing. This was important because the built-in event was only detecting one blocked connection at a time, and the helpful detection was grouping multiple instances of the same source/destination connection and checking if they formed a service-scan pattern.

7.5 ATT&CK Selection and Safety Mapping

Only the practical stages were selected from the mapping that was completed in Section A, and where a safe equivalent could be constructed. T1046 was scanned briefly using a Nmap SYN scan. A quick Nmap SYN scan was used to scan T1046. A local SMB account was created just for the lab and was used to represent Valid Accounts. Local Account Discovery was conducted with an Atomic Red Team test. Data Staged was simulated by compressing synthetic files, and Data Encrypted for Impact was simulated by encrypting the copies of the files with AES in Kali. Data Staged was simulated by compressing synthetic files, and Data Encrypted for Impact was simulated by encrypting copies of the files with AES in Kali. The method of the Change Healthcare exfiltration is unknown and the lab does not claim that TCP port 9001 was actually used during the real attack.

Stage	ATT&CK ID	Technique	Laboratory Implementation
Reconnaissance / Discovery	T1046	Network Service Scanning	Nmap SYN scan from Kali, observed in Wireshark, Windows Firewall and Wazuh.
Initial Access / Credential Use	T1078.003	Valid Accounts: Local Accounts	Controlled SMB login with labuser; one deliberate failed attempt followed by a success.
Discovery	T1087.001	Account Discovery: Local Account	Atomic Red Team test #9 plus manual discovery commands.
Collection	T1074	Data Staged	Synthetic healthcare files compressed into a ZIP archive.
Exfiltration	TA0010	Technique not asserted	Controlled TCP transfer of the synthetic archive to Kali.
Impact	T1486	Data Encrypted for Impact	AES encryption of copied synthetic files inside C:\LabImpactSim only.

Table 7: Controlled simulation mapping to MITRE ATT&CK.

8.0 Controlled Attack Simulation and Detection

8.1 Network Service Discovery with Nmap

The initial phase consisted of a controlled SYN scan of the Windows victim (192.168.6.133) by Kali 192.168.6.129. The first active phase was a SYN scan from Kali (192.168.6.129) to the Windows victim (192.168.6.133). The command targeted the top 20 ports and a medium timing template was employed ensuring the behaviour was clear but not overbearing. Windows Firewall prevented the connections from being initiated, and Wireshark revealed multiple TCP SYN packets sent by Kali to a variety of destination ports on the victim.

```
sudo nmap -sS -T3 --top-ports 20 192.168.6.133
```

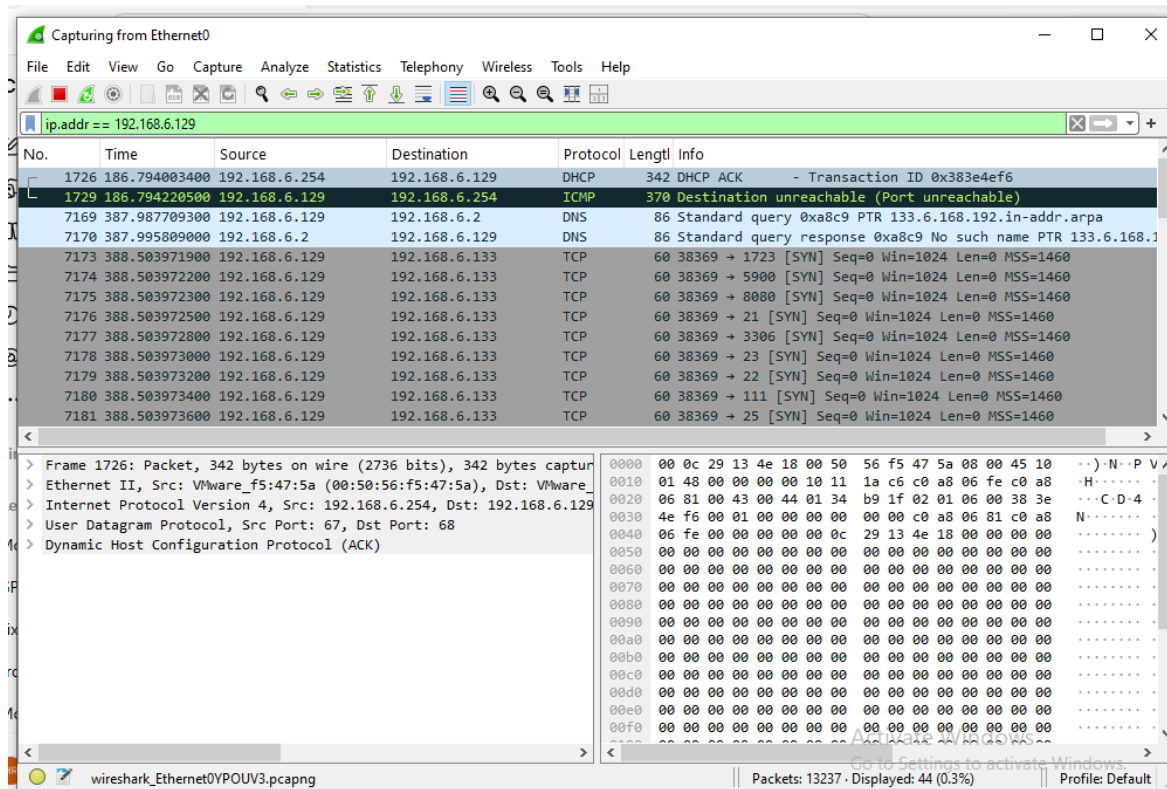


Figure 9: Nmap SYN reconnaissance from Kali 192.168.6.129 visible in Wireshark on the Windows victim.

Just a single firewall hit is not sufficient to classify it as a scan. Wazuh Rule 100200 is designed to detect inbound blocked TCP connections, first by using Windows Event ID 5157. Rule 100201 then matches six of the same events in 10 seconds with the source and destination addresses being the same. The high-level rule correlates to ATT&CK T1046 and issued a Level 10 alert. This is a stronger signal as it indicates multiple probes instead of denials.

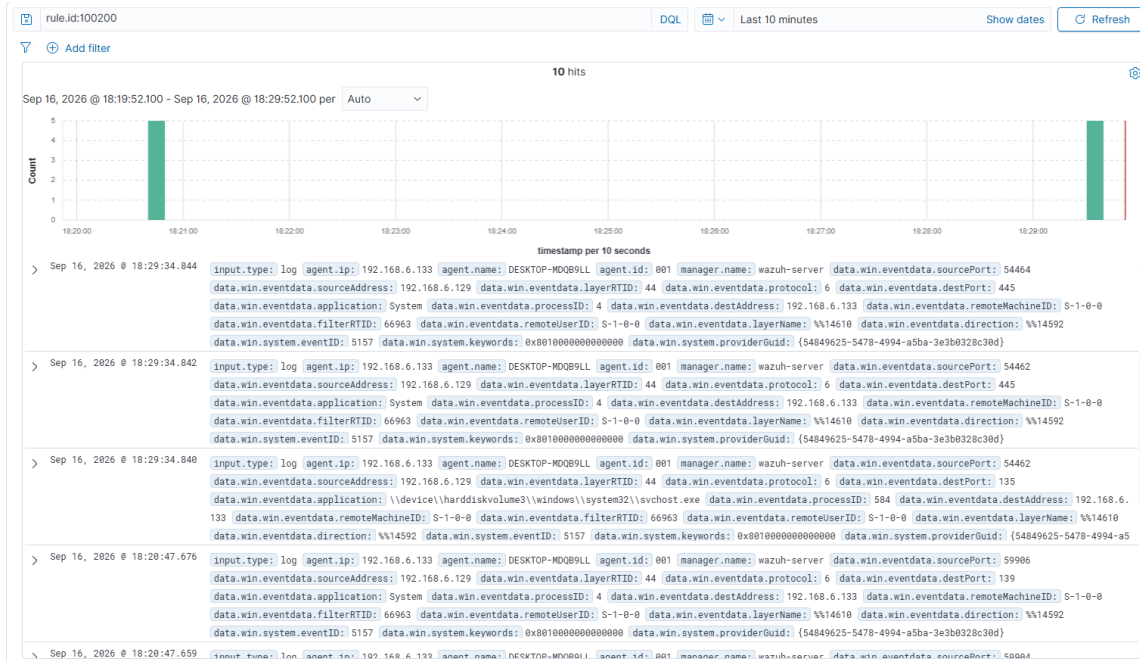


Figure 10: Wazuh Rule 100200 identifying a blocked inbound TCP connection from the Kali host.

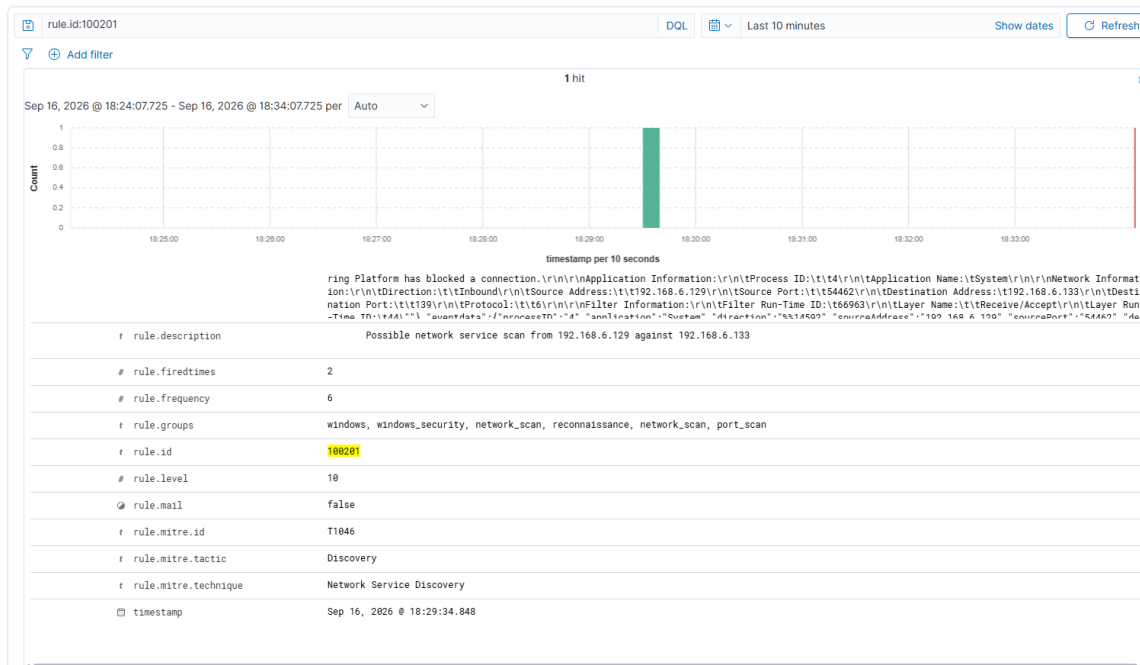
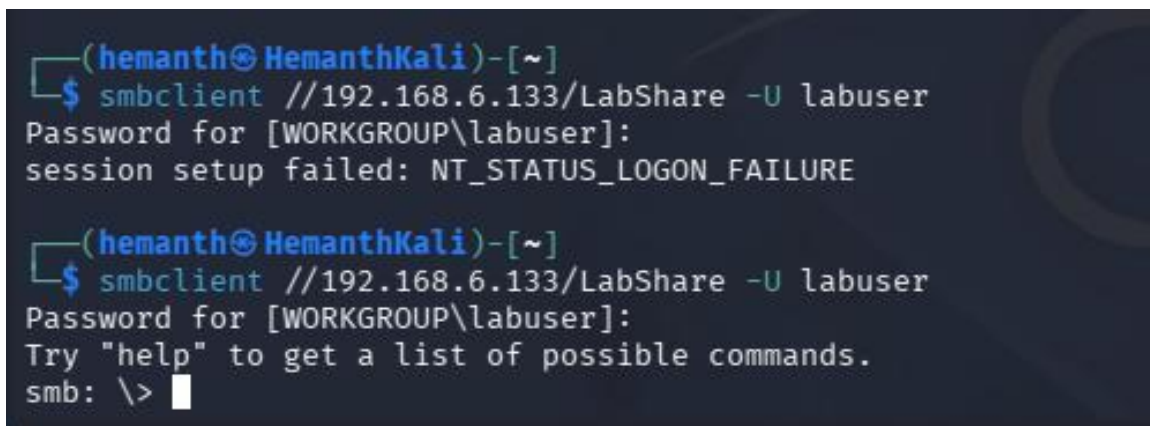


Figure 11: Correlated Wazuh Rule 100201 escalating repeated firewall blocks and mapping the activity to T1046.

8.2 Valid Account and SMB Access Simulation

A test account on the local Windows system called labuser was created and assigned a controlled share called LabShare. A test account was created on the local Windows system called labuser and was assigned to a controlled share called LabShare. This was meant to be a representation of the valid-account concept from Section A – it is not a rehash of the actual Citrix environment. Port 445 was only enabled because it was needed for the SMB stage. From Kali, a login was intentionally made with the wrong password, and then another login with the correct lab password.



```
(hemanth@HemanthKali)-[~]  
$ smbclient //192.168.6.133/LabShare -U labuser  
Password for [WORKGROUP\labuser]:  
session setup failed: NT_STATUS_LOGON_FAILURE  
  
(hemanth@HemanthKali)-[~]  
$ smbclient //192.168.6.133/LabShare -U labuser  
Password for [WORKGROUP\labuser]:  
Try "help" to get a list of possible commands.  
smb: \>
```

Figure 12: Deliberate failed SMB authentication followed by successful access to LabShare from Kali.

The failed login generated the windows event ID 4625, appeared in Wazuh with Logon Type 3, user labuser and source 192.168.6.129. A successful connection occurred, with an Event ID of 4624 and Logon Type of 3. Wazuh also applied a generic rule description, which included the term "possible pass-the-hash or RDP activity", but that was not considered proof. This was a normal SMB password logon as per protocol and lab procedure. For ATT&CK, the activity is considered to be not pass-the-hash, but Local Accounts (T1078.003).

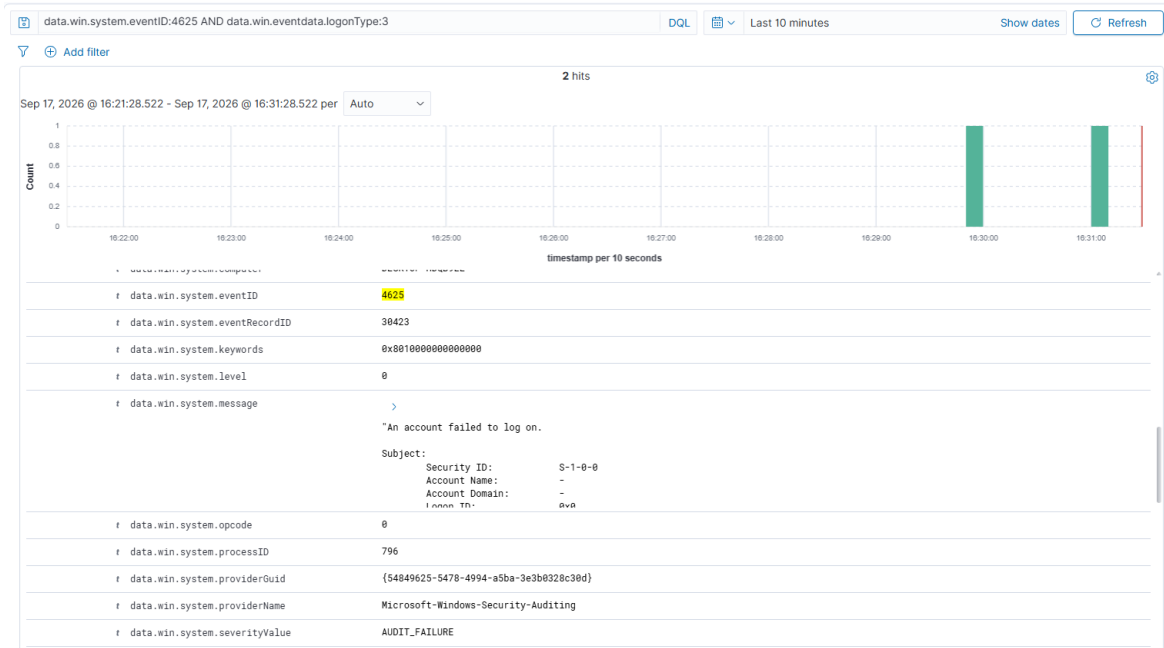


Figure 13: Wazuh view of Event ID 4625 and Logon Type 3 for the deliberately failed labuser SMB authentication.

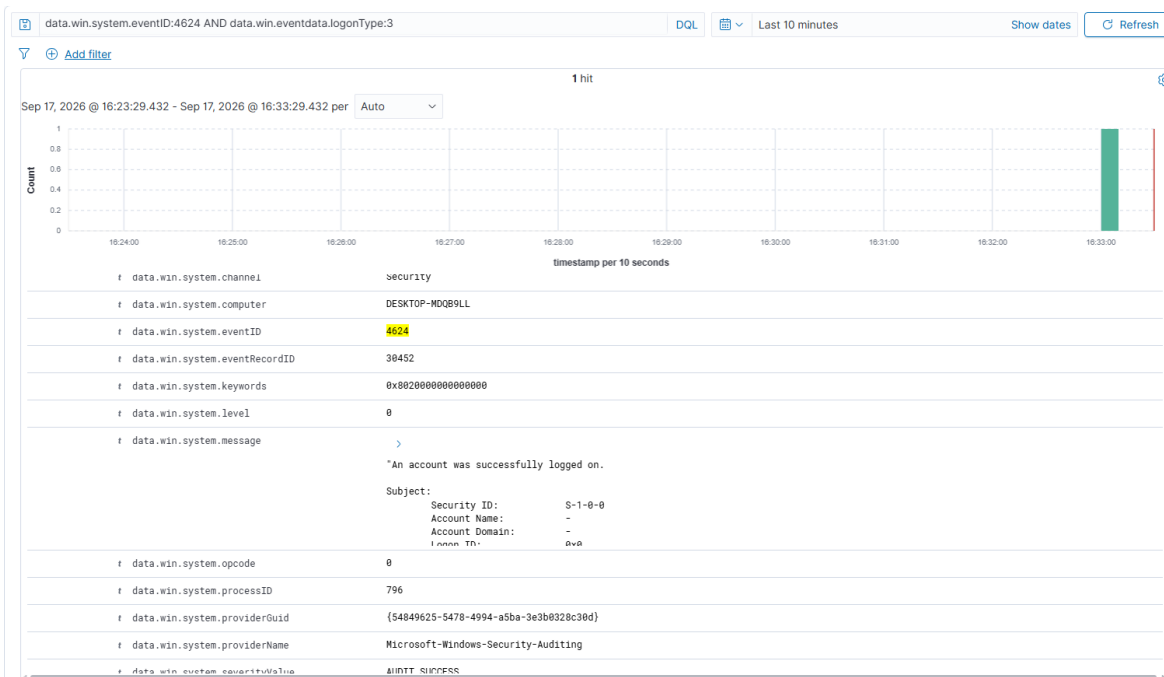


Figure 14: Wazuh view of Event ID 4624 and Logon Type 3 confirming successful network authentication by labuser.

8.3 Discovery and Atomic Red Team Validation

Several normal discovery commands were run on the Windows victim, including whoami, hostname, Get-LocalUser, Get-NetIPConfiguration and Get-Process. These actions were detected by creating a process (Sysmon Event ID 1). Not all commands created an independent Wazuh alert as is to be expected: discovery utilities are commonly used by legitimate administrators as well. It's about when and where the discovery is made, particularly if it coincides with suspicious network access.

Atomic Red Team was then used to create a known ATT&CK-aligned test. Technique T1087.001 test #9 enumerates local accounts through commands such as net user, Get-LocalUser, group membership checks, cmdkey and directory listings. The test was first reviewed with ShowDetails and then executed. This provided repeatable activity for checking whether Sysmon and other telemetry were present rather than relying only on manually typed commands (Red Canary, 2026).

```
Found 0 atomic tests applicable to windows platform for Technique
PS C:\Windows\system32> IEX (IWR 'https://raw.githubusercontent.com/redcanaryco/Invoke-AtomicRedTeam/master/install-atomicsfolder.ps1' -UseBasicParsing)
PS C:\Windows\system32> Install-AtomicsFolder
PS C:\Windows\system32> Test-Path "C:\AtomicRedTeam\atomics"
True
PS C:\Windows\system32> Test-Path "C:\AtomicRedTeam\atomics\T1087.001"
True
PS C:\Windows\system32> Invoke-AtomicTest T1087.001 -ShowDetailsBrief
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

T1087.001-8 Enumerate all accounts on Windows (Local)
T1087.001-9 Enumerate all accounts via PowerShell (Local)
T1087.001-10 Enumerate logged on users via CMD (Local)
T1087.001-11 ESXi - Local Account Discovery via ESXCLI
PS C:\Windows\system32> Invoke-AtomicTest T1087.001 -TestNumbers 9 -ShowDetails
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

[*****BEGIN TEST*****]
Technique: Account Discovery: Local Account T1087.001
Atomic Test Name: Enumerate all accounts via PowerShell (Local)
Atomic Test Number: 9
Atomic Test GUID: ae4b6361-b5f8-46cb-a3f9-9cf108ccfe7b
Description: Enumerate all accounts via PowerShell. Upon execution, lots of user account and group information will be displayed.

Attack Commands:
Executor: powershell
ElevationRequired: False
Command:
net user
get-localuser
get-localgroupmember -group Users
cmdkey.exe /list
ls C:\Users
get-childitem C:\Users\
dir C:\Users\
```

Figure 15: Invoke-AtomicRedTeam details for T1087.001 Atomic Test #9 before execution.

```

PS C:\Windows\system32> Get-WinEvent -FilterHashtable @{
>>   LogName='Microsoft-Windows-Sysmon/Operational'
>>   Id=1
>>   StartTime=(Get-Date).AddMinutes(-40)
>> } | Where-Object {
>>   $_.Message -match 'net.exe|cmdkey.exe|powershell.exe'
>> } | Format-List TimeCreated,Message

TimeCreated : 9/17/2026 6:12:04 PM
Message      : Process Create:
               RuleName: -
               UtcTime: 2026-09-17 10:12:04.881
               ProcessGuid: {203a754b-bcf4-6aab-a803-000000000600}
               ProcessId: 7200
               Image: C:\Windows\System32\whoami.exe
               FileVersion: 10.0.19041.1 (WinBuild.160101.0800)
               Description: whoami - displays logged on user information
               Product: Microsoft® Windows® Operating System
               Company: Microsoft Corporation
               OriginalFileName: whoami.exe
               CommandLine: "C:\Windows\system32\whoami.exe"
               CurrentDirectory: C:\Windows\system32\
               User: DESKTOP-MDQ89LL\heman
               LogonGuid: {203a754b-8ec1-6aab-69ba-280000000000}
               LogonId: 0x28BA69
               TerminalSessionId: 1
               IntegrityLevel: High
               Hashes: SHA256=1D4902A04D99E8CCBFE7085E63155955FEE397449D386453F6C452AE407B8743
               ParentProcessGuid: {203a754b-8ef9-6aab-4601-000000000600}
               ParentProcessId: 7436
               ParentImage: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
               ParentCommandLine: "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe"
               ParentUser: DESKTOP-MDQ89LL\heman

TimeCreated : 9/17/2026 6:12:04 PM
Message      : Process Create:
               RuleName: -
               UtcTime: 2026-09-17 10:12:04.861
               ProcessGuid: {203a754b-bcf4-6aab-a703-000000000600}
               ProcessId: 7784

```

Figure 16: Atomic Red Team T1087.001-9 execution producing local-account discovery activity.

8.4 Synthetic Data Staging

The collection stage used only fake healthcare-style data. Three files were created inside C:\LabData: Claims_Test_001.csv, Patient_Test_001.txt and Billing_Test_001.csv. They contained no real patient information. The files were compressed into Healthcare_Test_Archive.zip and hashed before transfer. This is a simple example of T1074 Data Staged because separate files were gathered into a single archive in preparation for movement.

```
PS C:\Windows\system32> New-Item -ItemType Directory -Path C:\LabData -Force

Directory: C:\
Mode                LastWriteTime         Length Name
----                -
d-----          9/16/2026   7:10 PM             LabData

PS C:\Windows\system32>
PS C:\Windows\system32> @
>> ClaimID, PatientID, Amount, Status
>> CLM-001, PAT-001, 1250.00, Approved
>> CLM-002, PAT-002, 780.50, Pending
>> " | Set-Content C:\LabData\Claims_Test_001.csv
PS C:\Windows\system32>
PS C:\Windows\system32> @
>> PatientID, PAT-001
>> Name: TEST PATIENT
>> Diagnosis: SYNTHETIC DATA ONLY
>> " | Set-Content C:\LabData\Patient_Test_001.txt
PS C:\Windows\system32>
PS C:\Windows\system32> @
>> InvoiceID, PatientID, Amount
>> INV-001, PAT-001, 1250.00
>> INV-002, PAT-002, 780.50
>> " | Set-Content C:\LabData\Billing_Test_001.csv
PS C:\Windows\system32> Get-Childitem C:\LabData

Directory: C:\LabData

Mode                LastWriteTime         Length Name
----                -
-a-----          9/17/2026   7:06 PM             75 Billing_Test_001.csv
-a-----          9/17/2026   7:06 PM             97 Claims_Test_001.csv
-a-----          9/16/2026   7:10 PM             39 Claims_Test_001.txt
-a-----          9/17/2026   7:06 PM             71 Patient_Test_001.txt
-a-----          9/11/2026  12:00 AM             25 test.txt
```

Figure 17: Three synthetic healthcare files created inside C:\LabData for the staging exercise.

```
PS C:\Windows\system32> Compress-Archive `
>> -Path C:\LabData\Claims_Test_001.csv,
>> C:\LabData\Patient_Test_001.txt,
>> C:\LabData\Billing_Test_001.csv `
>> -DestinationPath C:\LabData\Healthcare_Test_Archive.zip `
>> -Force
PS C:\Windows\system32> Get-FileHash C:\LabData\Healthcare_Test_Archive.zip -Algorithm SHA256

Algorithm      Hash
-----
SHA256         5FEAA1C63F7117634AAC46B0ACB624095002D9875A06E52C485205C2C370A7F5 C:\LabData\Healthcare_Test_Archive.zip
```

Figure 18: Healthcare_Test_Archive.zip created from the synthetic files and hashed before transfer.

8.5 Controlled Exfiltration Simulation

The exfiltration stage was performed by Kali via netcat listening on TCP port 9001 and the Windows victim using a short TCP client in PowerShell to send the ZIP file. This was a closed lab transfer (only synthetic data was transferred). It's an illustration of an outbound data movement concept but not the exact Change Healthcare exfiltration method as that too is not public.

The archive received was the same as the source file by SHA-256. This is important for the quality of the evidence since it indicates that the file that was observed on Kali was the same staged file from Windows. Wireshark also recorded the TCP session between 192.168.6.133 and 192.168.6.129 on port 9001 – the second independent record of the transfer.

```

(hemanth@HemanthKali)-[~]
$ nc -lvnp 9001 > Healthcare_Test_Archive_received.zip
listening on [any] 9001 ...
connect to [192.168.6.129] from (UNKNOWN) [192.168.6.133] 50901

(hemanth@HemanthKali)-[~]
$ ls -lh Healthcare_Test_Archive_received.zip
-rw-rw-r-- 1 hemanth hemanth 585 Sep 17 04:18 Healthcare_Test_Archive_received.zip

(hemanth@HemanthKali)-[~]
$ sha256sum Healthcare_Test_Archive_received.zip
5feaa1c63f7117634aac46b0acb624095002d9b75a06e52c485205c2c370a7f5 Healthcare_Test_Archive_received.zip

```

Figure 19: Kali receiving the synthetic archive and verifying its SHA-256 value after transfer.

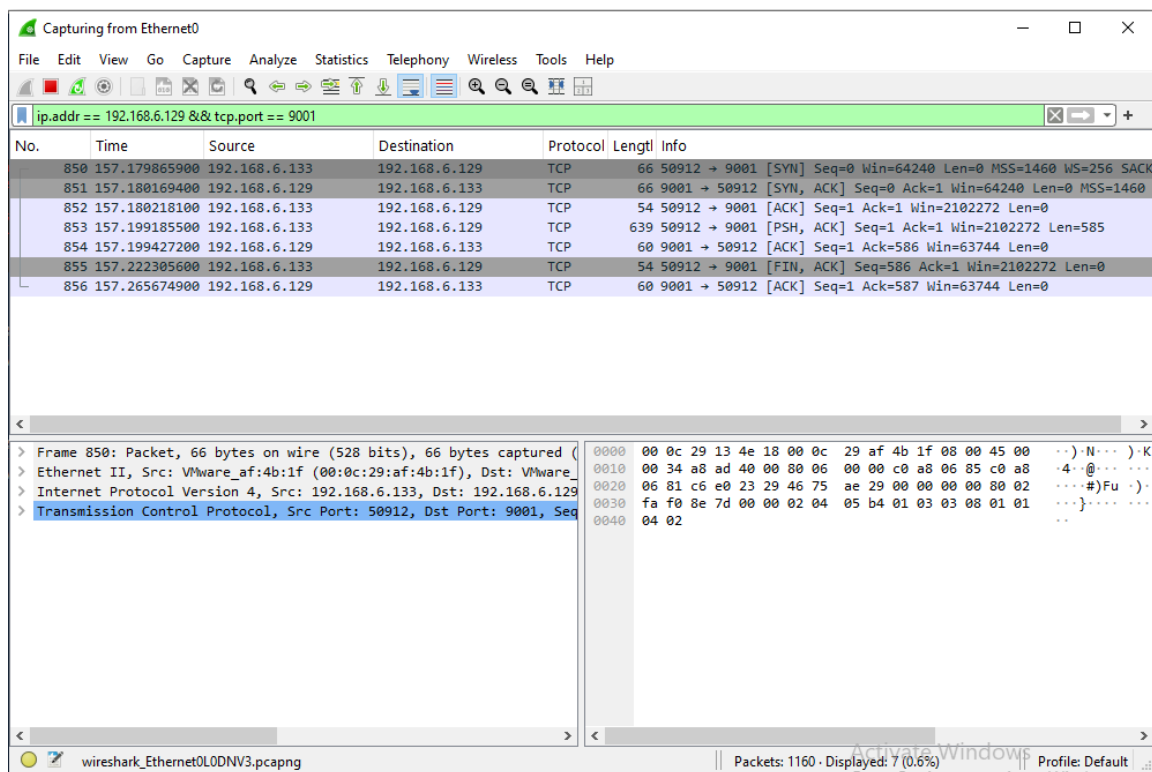


Figure 20: Wireshark capture of the controlled TCP transfer from Windows to Kali on port 9001.

8.6 Safe Encryption-Impact Simulation

The C:\LabImpactSim directory was explicitly set as the impact stage. The synthetic files were copied there, encrypted with AES using a new key, and the text versions of the synthetic files were deleted from the simulation folder. A README_SIMULATION.txt file and the

simulation key were left in place to review and reverse the behaviour. No changes were made to the original C:\LabData files.

This is the T1486 Data Encrypted for Impact level at behavioural. It is not actual ransomware and it does not try any of the following: Persistence, propagation, recovery inhibition, or destructive changes out of the test folder. This directory did not generate the FileCreate evidence which Sysmon was expecting because it had not been included in the tuned configuration, only C:\LabData and C:\LabTools. It is not hidden, but is noted as a convenient restriction of the monitoring configuration.

```
PS C:\Windows\system32> @"
>> RANSOMWARE IMPACT SIMULATION ONLY
>>
>> This file was created for an isolated cybersecurity laboratory exercise.
>> No real user data was encrypted.
>> Original synthetic test data remains safely stored in C:\LabData.
>> "@ | Set-Content C:\LabImpactSim\README_SIMULATION.txt
PS C:\Windows\system32> Get-ChildItem C:\LabImpactSim

Directory: C:\LabImpactSim

Mode                LastWriteTime         Length Name
----                -
-a----          9/17/2026   7:57 PM             96 Billing_Test_001.csv.locked
-a----          9/17/2026   7:57 PM            128 Claims_Test_001.csv.locked
-a----          9/17/2026   7:57 PM             96 Patient_Test_001.txt.locked
-a----          9/17/2026   7:57 PM            208 README_SIMULATION.txt
-a----          9/17/2026   7:57 PM             46 SIMULATION_KEY.txt
```

Figure 21: Simulation-only AES encryption results showing .locked files, retained key material and a simulation note.

```

PS C:\Windows\system32> Get-ChildItem C:\LabImpactSim

Directory: C:\LabImpactSim

Mode                LastWriteTime         Length Name
----                -
-a-----          9/17/2026   7:57 PM             96 Billing_Test_001.csv.locked
-a-----          9/17/2026   7:57 PM            128 Claims_Test_001.csv.locked
-a-----          9/17/2026   7:57 PM             96 Patient_Test_001.txt.locked
-a-----          9/17/2026   7:57 PM            208 README_SIMULATION.txt
-a-----          9/17/2026   7:57 PM             46 SIMULATION_KEY.txt

PS C:\Windows\system32> Get-FileHash C:\LabImpactSim\*.locked -Algorithm SHA256

Algorithm      Hash
-----
SHA256         79076D8889EC63DA1875C7A89822B94C28383B4D21B0B7F604A483C506E23DCA
SHA256         A7792E3227C23916CD3484A9DD9949D27C823199D7DD88DCAFFE9FB3178605C5
SHA256         FC2ADE699424A722018FDCA21E11527C695E0F3A03785B404324F7B3C5C3EC04
C:\LabImpactSim\Billing_Test_001.csv.locked
C:\LabImpactSim\Claims_Test_001.csv.locked
C:\LabImpactSim\Patient_Test_001.txt.locked

PS C:\Windows\system32> Get-ChildItem C:\LabData

Directory: C:\LabData

Mode                LastWriteTime         Length Name
----                -
-a-----          9/17/2026   7:06 PM             75 Billing_Test_001.csv
-a-----          9/17/2026   7:06 PM             97 Claims_Test_001.csv
-a-----          9/16/2026   7:10 PM             39 Claims_Test_001.txt
-a-----          9/17/2026   7:09 PM            585 Healthcare_Test_Archive.zip
-a-----          9/17/2026   7:06 PM             71 Patient_Test_001.txt
-a-----          9/11/2026  12:00 AM             25 test.txt

```

Figure 22: Comparison of intact source files in C:\LabData with encrypted simulation copies in C:\LabImpactSim.

8.7 Laboratory Indicators and Observables

The practical resulted in a valuable set of laboratory indicators which can be correlated to the stages of the attack. These are not actual Change Healthcare IOCs, these are only in the controlled environment. Ensuring the clear distinction between the label and simulated threat intelligence prevents the confusion of artefacts with real threat information.

Indicator / Observable	Lab Meaning	Detection / Evidence
192.168.6.129	Kali attacker / analysis VM	Wireshark, firewall events, Wazuh authentication events
192.168.6.133	Windows victim endpoint	Windows logs, Sysmon, Wireshark and Volatility
Windows Event ID 5157	Blocked inbound connection	Wazuh Rule 100200 and correlation into Rule 100201
Windows Event ID 4625	Failed network authentication	Wazuh failed-logon evidence

Indicator / Observable	Lab Meaning	Detection / Evidence
Windows Event ID 4624, Logon Type 3	Successful network authentication	Wazuh and Windows Security logs
TCP 445	SMB service used for valid-account test	Nmap / netscan / SMB activity
TCP 9001	Controlled synthetic-data transfer	Wireshark and netcat
Healthcare_Test_Archive.zip	Staged synthetic data	Filesystem and SHA-256 evidence
.locked files in C:\LabImpactSim	Controlled encryption-impact artefacts	Filesystem, hashes and simulation note
powershell.exe activity	Discovery, transfer and impact scripting context	Sysmon and Volatility process evidence

Table 8: Laboratory indicators and observables generated during the controlled simulation.

8.8 Detection Results Summary

Quality of detection was best when the lab was equipped with the proper telemetry and a correlation rule of any value. The reconnaissance with Nmap generated packet evidence, firewall events and Wazuh alert level 10. Good 4625 and 4624 records were made by authentication tests. Discovery could be seen through process creation, but benign administrative commands might not necessarily warrant a high severity alert. There were no specific SIEM behaviours for staging or encryption, but these behaviors could be easily identified in the filesystems. This distinction matters: Adding a monitoring product doesn't necessarily mean good detections. The scope and design of the rules are still important in logging.

Activity	Primary Evidence	Detection Assessment
Nmap reconnaissance	Wireshark SYN traffic; Event 5157; Wazuh Rules 100200/100201	Strong – correlated Level 10 scan alert.

Activity	Primary Evidence	Detection Assessment
Failed SMB authentication	Windows Event 4625 / Wazuh	Strong – source, user and network logon type visible.
Successful SMB authentication	Windows Event 4624 / Wazuh	Strong – successful Logon Type 3 visible; analyst validation corrected generic rule wording.
Discovery commands	Sysmon Event ID 1	Moderate – process evidence present; no need for a dedicated alert on every benign command.
Atomic T1087.001-9	Known Atomic execution plus process telemetry	Moderate – useful for validating endpoint visibility.
Data staging	Filesystem/archive and SHA-256 evidence	Moderate – clear artefact, no dedicated SIEM rule.
TCP exfiltration	Netcat receiver, Wireshark and matching hashes	Strong network evidence; no bespoke Wazuh exfiltration rule.
AES impact simulation	.locked files, hashes and simulation note	Strong filesystem evidence; Sysmon file-create scope did not include LabImpactSim.

Table 9: Detection and evidence summary for the controlled simulation.

9.0 Digital Forensics and Evidence Analysis

9.1 Evidence Collection and Integrity

There's been more than just screenshots of the evidence preserved. Windows Security and Sysmon logs were exported, the firewall log was retained, the impact-simulation directory was copied to an evidence folder and the Wireshark PCAP was retained. Key artefacts have been hashed with the SHA-256 hash function to ensure that the evidence was not altered in any way in subsequent analysis.

Evidence ID	Artefact	Purpose
E01	Security.evtx	Windows authentication, audit and security events.
E02	Sysmon.evtx	Process creation and endpoint telemetry.
E03	pfirewall.log	Dropped inbound connection records.
E04	LabImpactSim directory	Encrypted simulation files, note and key material.
E05	Wireshark PCAP	Nmap and controlled-transfer network evidence.
E06	VMware .vmem + .vmss	Memory image and metadata used for Volatility 3 analysis.

Table 10: Digital forensic evidence register.

```

PS C:\Windows\system32> wevtutil epl Security C:\ForensicEvidence\Security.evtx
PS C:\Windows\system32> wevtutil epl "Microsoft-Windows-Sysmon/Operational" C:\ForensicEvidence\Sysmon.evtx
PS C:\Windows\system32> Copy-Item `
>> "C:\Windows\System32\LogFiles\Firewall\pfirewall.log" `
>> "C:\ForensicEvidence\pfirewall.log"
PS C:\Windows\system32> Copy-Item C:\LabImpactSim C:\ForensicEvidence\LabImpactSim -Recurse
PS C:\Windows\system32> Get-ChildItem C:\ForensicEvidence -Recurse |
>> Select-Object FullName,Length,LastWriteTime

FullName                                     Length  LastWriteTime
-----
C:\ForensicEvidence\LabImpactSim
C:\ForensicEvidence\pfirewall.log           9064    9/17/2026 3:14:53 PM
C:\ForensicEvidence\Security.evtx          21041152 9/17/2026 8:27:12 PM
C:\ForensicEvidence\Sysmon.evtx            66129920 9/17/2026 8:27:17 PM
C:\ForensicEvidence\LabImpactSim\Billing_Test_001.csv.locked 96       9/17/2026 7:57:29 PM
C:\ForensicEvidence\LabImpactSim\Claims_Test_001.csv.locked 128      9/17/2026 7:57:29 PM
C:\ForensicEvidence\LabImpactSim\Patient_Test_001.txt.locked 96       9/17/2026 7:57:29 PM
C:\ForensicEvidence\LabImpactSim\README_SIMULATION.txt      208     9/17/2026 7:57:39 PM
C:\ForensicEvidence\LabImpactSim\SIMULATION_KEY.txt          46       9/17/2026 7:57:28 PM

PS C:\Windows\system32> Get-FileHash `
>> C:\ForensicEvidence\Security.evtx,
>> C:\ForensicEvidence\Sysmon.evtx,
>> C:\ForensicEvidence\pfirewall.log `
>> -Algorithm SHA256

Algorithm    Hash                                          Path
-----
SHA256       CC290718A29A71CC3AE157E45C6AE13DC7EF8D371773058A354C928CD8081B54  C:\ForensicEvidence\Security.evtx
SHA256       32CB60E190B67B4225E9034CA7ED81B69AF631F5F8D2439FFA610C198113C40  C:\ForensicEvidence\Sysmon.evtx
SHA256       06D678DFAC5767D878A23F62EB475B58E8CF58FFB8B20124B94473C18C8E6197  C:\ForensicEvidence\pfirewall.log

```

Figure 23: Exported forensic evidence and SHA-256 integrity values for the collected artefacts.

9.2 Host and Event Log Correlation

The logs of the event are very good at reconstructing the early stages. The blocked inbound connections are recorded on Event ID 5157. Event ID 4625 indicates the intentional failure of SMB authentication, and Event ID 4624 and Logon Type 3 indicates that it was

successfully logged on to the network. New process-level context for discovery and Atomic Red Team commands in Sysmon Event ID 1. Each event is limited on its own, but when they are arranged in chronological order they display a much more clearly defined progression from probing to credential use to credential discovery.

The Wazuh rule behaviour also exemplifies the importance of human interpretation of the rules. The successful SMB login matched a very general rule that included the possibility of pass-the-hash or RDP. The real protocol, account and test procedure was otherwise. A rule in a SIEM is not a definitive indicator of a particular attacker technique.

9.3 Network Forensics

Wireshark offers direct evidence of network for two important points. During the Nmap test, it captured windows SYN packets sent by Kali to several ports of the windows victim. During the transfer test, it recorded TCP traffic between 192.168.6.133 and 192.168.6.129 on port 9001. The PCAP can thus be used to support the reconnaissance phase of the lab without Wazuh and additionally for the exfiltration phase separately from Wazuh.

While the network evidence may also be compared to other evidence. The firewall events confirm that the initial scan traffic was blocked by the Windows firewall, and the matching SHA-256 values confirm that the file received on Kali was the same staged one used in the initial scan. This type of evidence correlation is far more effective than a single screen shot or single tool.

9.4 Memory Forensics with Volatility 3

Some trouble shooting was needed to acquire memory. In a first WinPmem try, a 6.46 GB raw file was generated on an 8 GB VM and a cancellation message was received at the end. Volatility was not able to create a valid Windows layer from that file. The Windows VM was suspended, and the resultant 8GB VMware .vmem file was analysed in parallel with the associated VMware metadata file, .vmss. This second way was the right one.

```

PS C:\LabTools\WinPmem> .\go-winpmem_amd64_1.0-rc2_signed.exe acquire C:\ForensicEvidence\memory.raw
Writing driver to C:\Users\heman\AppData\Local\Temp\3011955397.sys
Creating service winpmem
Installed service winpmem
Started service winpmem
Memory Info:

CR3: 0x1ad002
NtBuildNumber: 0x4a65
KernelBase: 0xfffff80624c00000
KPCR:
- 0xfffff8061fcd3000
NtBuildNumberAddr: 0xfffff80625812120
Run:
- BaseAddress: 0x2000
  NumberOfBytes: 0x9e000
- BaseAddress: 0x100000
  NumberOfBytes: 0xd9ee000
- BaseAddress: 0xdaef000
  NumberOfBytes: 0x2080000
- BaseAddress: 0xfbff000
  NumberOfBytes: 0xb0401000
- BaseAddress: 0x100000000
  NumberOfBytes: 0x140000000

Setting sparse output file C:\ForensicEvidence\memory.raw
Padding 2 pages from 0x0
Copying 158 pages (0x9e000) from 0x2000
Padding 96 pages from 0xa0000
Copying 55790 pages (0xd9ee000) from 0x100000
Padding 1 pages from 0xdaee000
Copying 8320 pages (0x2080000) from 0xdaef000
Padding 144 pages from 0xfb6f000
Copying 721921 pages (0xb0401000) from 0xfbff000
Padding 262144 pages from 0xc0000000
Copying 1310720 pages (0x140000000) from 0x100000000
Completed imaging in 1h1m21.0173804s
Stopped service winpmem
Removing driver from C:\Users\heman\AppData\Local\Temp\3011955397.sys

```

Figure 24: WinPmem acquisition attempt showing imaging completion followed by cancellation during final handling.

```

(hemanth@HemanthKali)-[~/volatility3]
$ ls -lh "/mnt/hgfs/VMShare-2"
total 15G
-rwxrwxrwx 1 root root 6.5G Sep 17 08:10 memory.raw
-rwxrwxrwx 1 root root 8.0G Sep 17 08:36 'Windows 10 x64-80e1c10a.vmem'
-rwxrwxrwx 1 root root 3.8M Sep 17 09:33 'Windows 10 x64-80e1c10a.vmss'

```

Figure 25: VMware memory image and matching VMSS metadata exposed to Kali through the shared folder.

Volatility 3 was able to successfully mount a 64-bit Windows 10 memory image and format the image as a VMware translation layer. The system time that was reported was 17 September 2026 16:33:39 UTC and the built of the OS was 19041. The successful windows.info output was the only validation that was important for the memory source.

```

(hemanth@HemanthKali) [~/volatility3]
$ cd ~/volatility3
python3 vol.py -f "/mnt/hgfs/VMShare-2/Windows 10 x64-80e1c10a.vmem" windows.info
Volatility 3 Framework 2.28.2
Progress: 100.00 PDB scanning finished
Variable Value
Kernel Base 0xf8007f400000
DTB 0x1ad000
Symbols file:///home/hemanth/volatility3/volatility3/symbols/windows/ntkrnlmp.pdb/F57E740B088E5056E8AF0772F1CC58EB-1.json.xz
Is64Bit True
IsPAE False
layer_name 0 WindowsIntel32e
memory_layer 1 VmwareLayer
base_layer 2 FileLayer
meta_layer 2 FileLayer
KdVersionBlock 0xf8008000f400
Major/Minor 15.19041
MachineType 34404
KeNumberProcessors 1
SystemTime 2026-09-17 16:33:39+00:00
NtSystemRoot C:\Windows
NtProductType NtProductWinNt
NtMajorVersion 10
NtMinorVersion 0
PE MajorOperatingSystemVersion 10
PE MinorOperatingSystemVersion 0
PE Machine 34404
PE TimeDateStamp Sat Feb 2 23:04:03 1985
Exception ignored in: <function MagicDetect.__del__ at 0x7f4e355a6020>
Traceback (most recent call last):
  File "/usr/lib/python3/dist-packages/magic/compat.py", line 299, in __del__
  File "/usr/lib/python3/dist-packages/magic/compat.py", line 126, in close
TypeError: 'NoneType' object is not callable
(hemanth@HemanthKali) [~/volatility3]

```

Figure 26: Volatility 3 windows.info successfully identifying the Windows 10 x64 VMware memory image.

The expected Windows process set and security tooling was observed in the process analysis. The Sysmon64.exe process was active, and the Wazuh agent was active, and PowerShell processes were seen throughout the captured time. The process tree was quite similar to a typical Windows session as opposed to a true ransomware attack, which should be the case since the lab's ransomware was a harmless script. The path to the PowerShell executables was recovered from the command line plugin, but not the full command lines used previously, so these are correlated by Sysmon and from the known lab procedure as well as those that were claimed from memory.

```

(hemanth@Hemanthkali) ~/volatility3
$ python3 vol.py -f "/mnt/hgfs/VMShare-2/Windows 10 x64-80e1c10a.vmem" windows.plist
Volatility 3 Framework 2.28.2
Progress: 100.00
PDB scanning finished
PID PPID ImageFileName Offset(V) Threads Handles SessionId Wow64 CreateTime E
xitTime File output
4 0 System 0xa18c37e64080 120 - N/A False 2026-09-17 15:58:45.000000 UT
C N/A Disabled
72 4 Registry 0xa18c37f17080 4 - N/A False 2026-09-17 15:58:39.0
00000 UTC
536 4 smss.exe 0xa18c38c07040 2 - N/A False 2026-09-17 15:58:45.0
00000 UTC
636 628 csrss.exe 0xa18c3b0a6140 10 - 0 False 2026-09-17 15:58:46.0
00000 UTC
716 628 wininit.exe 0xa18c3b9bc080 1 - 0 False 2026-09-17 15:58:46.0
00000 UTC
724 708 csrss.exe 0xa18c3b9bf140 12 - 1 False 2026-09-17 15:58:46.0
00000 UTC
768 708 winlogon.exe 0xa18c3b9f5080 5 - 1 False 2026-09-17 15:58:46.0
00000 UTC
836 716 services.exe 0xa18c3c01e080 7 - 0 False 2026-09-17 15:58:47.0
00000 UTC
844 716 lsass.exe 0xa18c38a8c080 10 - 0 False 2026-09-17 15:58:47.0
00000 UTC
928 768 fontdrvhost.ex 0xa18c3c08b140 5 - 1 False 2026-09-17 15:58:47.0
00000 UTC
936 716 fontdrvhost.ex 0xa18c3c08e140 5 - 0 False 2026-09-17 15:58:47.0
00000 UTC
952 836 svchost.exe 0xa18c3c091240 16 - 0 False 2026-09-17 15:58:47.0
00000 UTC
568 836 svchost.exe 0xa18c3c1182c0 12 - 0 False 2026-09-17 15:58:47.0
00000 UTC
608 836 svchost.exe 0xa18c3c13f240 5 - 0 False 2026-09-17 15:58:47.0
00000 UTC
1044 768 dwm.exe 0xa18c3c171080 16 - 1 False 2026-09-17 15:58:47.000000 UT
C N/A Disabled
1132 836 svchost.exe 0xa18c3c2092c0 2 - 0 False 2026-09-17 15:58:48.0
00000 UTC
1172 836 svchost.exe 0xa18c3c227300 3 - 0 False 2026-09-17 15:58:48.0
00000 UTC
1188 836 svchost.exe 0xa18c3c22c280 5 - 0 False 2026-09-17 15:58:48.0
00000 UTC
1204 836 svchost.exe 0xa18c3c231300 4 - 0 False 2026-09-17 15:58:48.0
00000 UTC
1308 836 svchost.exe 0xa18c3c2b9240 9 - 0 False 2026-09-17 15:58:48.0
00000 UTC
1340 836 svchost.exe 0xa18c3c2d1300 3 - 0 False 2026-09-17 15:58:48.0
00000 UTC
N/A Disabled

```

Figure 27: Volatility windows.plist output showing the active Windows process set.

```

(hemanth@Hemanthkali) ~/volatility3
$ python3 vol.py -f "/mnt/hgfs/VMShare-2/Windows 10 x64-80e1c10a.vmem" windows.pstree
Volatility 3 Framework 2.28.2
Progress: 100.00
PDB scanning finished
PID PPID ImageFileName Offset(V) Threads Handles SessionId Wow64 CreateTime ExitTime Audit Cmd Path
4 0 System 0xa18c37e64080 120 - N/A False 2026-09-17 15:58:45.000000 UTC N/A - - -
* 72 4 Registry 0xa18c37f17080 4 - N/A False 2026-09-17 15:58:39.000000 UTC N/A - - -
* 536 4 smss.exe 0xa18c38c07040 2 - N/A False 2026-09-17 15:58:45.000000 UTC N/A - - -
SystemRoot\System32\smss.exe
* 636 628 csrss.exe 0xa18c3b0a6140 10 - N/A False 2026-09-17 15:58:46.000000 UTC N/A - - -
SystemRoot\System32\csrss.exe
* 716 628 wininit.exe 0xa18c3b9bc080 1 - 0 False 2026-09-17 15:58:46.000000 UTC N/A - - -
C:\Windows\system32\wininit.exe
* 724 708 csrss.exe 0xa18c3b9bf140 12 - 1 False 2026-09-17 15:58:46.000000 UTC N/A - - -
C:\Windows\system32\csrss.exe
* 768 708 winlogon.exe 0xa18c3b9f5080 5 - 1 False 2026-09-17 15:58:46.000000 UTC N/A - - -
C:\Windows\system32\winlogon.exe
* 836 716 services.exe 0xa18c3c01e080 7 - 0 False 2026-09-17 15:58:47.000000 UTC N/A - - -
C:\Windows\system32\services.exe
* 844 716 lsass.exe 0xa18c38a8c080 10 - 0 False 2026-09-17 15:58:47.000000 UTC N/A - - -
C:\Windows\system32\lsass.exe
* 928 768 fontdrvhost.exe 0xa18c3c08b140 5 - 1 False 2026-09-17 15:58:47.000000 UTC N/A - - -
C:\Windows\system32\fontdrvhost.exe
* 936 716 fontdrvhost.exe 0xa18c3c08e140 5 - 0 False 2026-09-17 15:58:47.000000 UTC N/A - - -
C:\Windows\system32\fontdrvhost.exe
* 952 836 svchost.exe 0xa18c3c091240 16 - 0 False 2026-09-17 15:58:47.000000 UTC N/A - - -
C:\Windows\system32\svchost.exe
* 568 836 svchost.exe 0xa18c3c1182c0 12 - 0 False 2026-09-17 15:58:47.000000 UTC N/A - - -
C:\Windows\system32\svchost.exe
* 608 836 svchost.exe 0xa18c3c13f240 5 - 0 False 2026-09-17 15:58:47.000000 UTC N/A - - -
C:\Windows\system32\svchost.exe
* 1044 768 dwm.exe 0xa18c3c171080 16 - 1 False 2026-09-17 15:58:47.000000 UTC N/A - - -
C:\Windows\system32\dwm.exe
* 1132 836 svchost.exe 0xa18c3c2092c0 2 - 0 False 2026-09-17 15:58:48.000000 UTC N/A - - -
C:\Windows\system32\svchost.exe
* 1172 836 svchost.exe 0xa18c3c227300 3 - 0 False 2026-09-17 15:58:48.000000 UTC N/A - - -
C:\Windows\system32\svchost.exe
* 1188 836 svchost.exe 0xa18c3c22c280 5 - 0 False 2026-09-17 15:58:48.000000 UTC N/A - - -
C:\Windows\system32\svchost.exe
* 1204 836 svchost.exe 0xa18c3c231300 4 - 0 False 2026-09-17 15:58:48.000000 UTC N/A - - -
C:\Windows\system32\svchost.exe
* 1308 836 svchost.exe 0xa18c3c2b9240 9 - 0 False 2026-09-17 15:58:48.000000 UTC N/A - - -
C:\Windows\system32\svchost.exe
* 1340 836 svchost.exe 0xa18c3c2d1300 3 - 0 False 2026-09-17 15:58:48.000000 UTC N/A - - -
C:\Windows\system32\svchost.exe
* 2864 836 Sysmon64.exe 0xa18c3c9a2100 16 - 0 False 2026-09-17 15:58:53.000000 UTC N/A - - -
C:\Windows\Sysmon64.exe
* 2584 836 svchost.exe 0xa18c3c760800 5 - 0 False 2026-09-17 15:58:51.000000 UTC N/A - - -
C:\Windows\system32\svchost.exe
* 2808 836 svchost.exe 0xa18c3c44a080 12 - 0 False 2026-09-17 15:58:50.000000 UTC N/A - - -
C:\Windows\system32\svchost.exe
* 2896 836 svchost.exe 0xa18c3b99b080 5 - 0 False 2026-09-17 15:58:50.000000 UTC N/A - - -
C:\Windows\system32\svchost.exe
* 568 836 svchost.exe 0xa18c3c1182c0 12 - 0 False 2026-09-17 15:58:47.000000 UTC N/A - - -
C:\Windows\system32\svchost.exe
* 5180 836 svchost.exe 0xa18c3c9d6140 5 - 0 False 2026-09-17 15:59:05.000000 UTC N/A - - -
C:\Windows\system32\svchost.exe
* 5120 5180 ctfmon.exe 0xa18c3c5d0800 10 - 1 False 2026-09-17 15:59:06.000000 UTC N/A - - -
C:\Windows\system32\ctfmon.exe
* 5696 836 svchost.exe 0xa18c3c8b2080 8 - 0 False 2026-09-17 15:59:08.000000 UTC N/A - - -
C:\Windows\system32\svchost.exe
* 3652 836 SearchIndexer.exe 0xa18c3cbe2400 18 - 0 False 2026-09-17 15:58:56.000000 UTC N/A - - -
C:\Windows\system32\SearchIndexer.exe

```

Figure 28: Volatility windows.pstree output used to examine process relationships in memory.

```

(hemant@hemantkali):~/volatility3
python3 vol.py -f "/mnt/hgfs/VMShare-2/Windows 10 x64-80e1c10a.vmem" windows.cmdline
Volatility 3 Framework 2.2b.2
Progress: 100.00 PDB scanning finished
PID Process Args
4 System -
72 Registry -
336 smss.exe \SystemRoot\System32\lsass.exe
336 csrss.exe \SystemRoot\System32\csrss.exe ObjectDirectory=\Windows SharedSection=1824,20480,768 Windows=On SubSystemType=Windows ServerDll=basesrv,1 ServerDll=winhttp:UserServerDllInitialization,3 5
serverDll=sslsrv,4 ProfileControl=Off MaxRequestThreads=16
716 wininit.exe wininit.exe
724 csrss.exe \SystemRoot\System32\csrss.exe ObjectDirectory=\Windows SharedSection=1824,20480,768 Windows=On SubSystemType=Windows ServerDll=basesrv,1 ServerDll=winhttp:UserServerDllInitialization,3 5
serverDll=sslsrv,4 ProfileControl=Off MaxRequestThreads=16
768 winlogon.exe winlogon.exe
836 services.exe C:\Windows\System32\services.exe
844 lsass.exe C:\Windows\System32\lsass.exe
928 fontdrvhost.exe "fontdrvhost.exe"
936 fontdrvhost.exe C:\Windows\System32\svchost.exe -k DcomLaunch -p
952 svchost.exe C:\Windows\System32\svchost.exe -k RPCSS -p
968 svchost.exe C:\Windows\System32\svchost.exe -k DcomLaunch -p -s LSM
1044 dm.exe "dm.exe"
1132 svchost.exe C:\Windows\System32\svchost.exe -k LocalServiceNetwork -p
1172 svchost.exe C:\Windows\System32\svchost.exe -k LocalServiceNetworkRestricted -p -s lmhosts
1188 svchost.exe C:\Windows\System32\svchost.exe -k LocalSystemNetworkRestricted -p -s NcbService
1204 svchost.exe C:\Windows\System32\svchost.exe -k LocalServiceNetworkRestricted -p -s TimeBrokerSvc
1388 svchost.exe C:\Windows\System32\svchost.exe -k netsvc -p -s Schedule
1340 svchost.exe C:\Windows\System32\svchost.exe -k LocalService -p -s DisplayBrokerDesktopSvc
1356 svchost.exe C:\Windows\System32\svchost.exe -k LocalServiceNetworkRestricted -p -s EventLog
1426 svchost.exe C:\Windows\System32\svchost.exe -k netsvc -p -s ProfSvc
1444 svchost.exe C:\Windows\System32\svchost.exe -k LocalService -p -s mail
1516 svchost.exe C:\Windows\System32\svchost.exe -k netsvc -p -s UserManager
1528 svchost.exe C:\Windows\System32\svchost.exe -k LocalServiceNetworkRestricted -p -s Dhcp
1628 svchost.exe C:\Windows\System32\svchost.exe -k NetworkService -p -s NlaSvc
1664 svchost.exe C:\Windows\System32\svchost.exe -k LocalService -p
1712 svchost.exe C:\Windows\System32\svchost.exe -k LocalService -p -s EventSystem
1728 svchost.exe C:\Windows\System32\svchost.exe -k LocalSystemNetworkRestricted -p -s SysMain
1756 svchost.exe C:\Windows\System32\svchost.exe -k netsvc -p -s Themes
1836 svchost.exe C:\Windows\System32\svchost.exe -k netsvc -p -s SENS
1856 MemCompression
1884 svchost.exe C:\Windows\System32\svchost.exe -k LocalService -p -s netprof
1892 svchost.exe C:\Windows\System32\svchost.exe -k LocalSystemNetworkRestricted -p -s AudioEndpointBuilder
1912 svchost.exe C:\Windows\System32\svchost.exe -k LocalService -p -s FontCache
1188 svchost.exe C:\Windows\System32\svchost.exe -k LocalServiceNetworkRestricted -p
1500 svchost.exe C:\Windows\System32\svchost.exe -k LocalServiceNetworkRestricted -s RmSvc
1876 svchost.exe C:\Windows\System32\svchost.exe -k LocalSystemNetworkRestricted -p -s NgSvc
2088 svchost.exe C:\Windows\System32\svchost.exe -k NetworkService -p -s DnsCache
2096 svchost.exe C:\Windows\System32\svchost.exe -k LocalServiceNetworkRestricted -p

```

Figure 29: Volatility windows.cmdline output showing available process command-line information.

The victim IP address and an SMB service that was listening on TCP 445 appeared in the netscan plugin's list, consistent with the previous SMB test. When the VM was suspended the short-lived TCP 9001 transfer was not in memory anymore, so the PCAP file is the better evidence for that stage. Additionally, a filescan search was not effective in recovering LabData or .locked filenames, just unrelated Windows files with the word 'Simulation' were matched. This negative result remains a limitation, rather than being forced into a positive one.

```
(hemanth@HemanthKali)-[~/volatility3]
$ python3 vol.py -f "/mnt/hgfs/VMShare-2/Windows 10 x64-80e1c10a.vmem" windows.netscan
Volatility 3 Framework 2.28.2
Progress: 100.00
Offset Proto LocalAddr PDB scanning finished ForeignAddr ForeignPort State PID Owner Created
0xa18c37ea7050 TCPv4 0.0.0.0 5357 0.0.0.0 0 LISTENING 4 System 2026-09-17 15:58:52.000000 UTC
0xa18c37ea7050 TCPv6 :: 5357 :: 0 LISTENING 4 System 2026-09-17 15:58:52.000000 UTC
0xa18c37ea7470 TCPv4 0.0.0.0 49667 0.0.0.0 0 LISTENING 1308 svchost.exe 2026-09-17 15:58:49.000000 UTC
0xa18c37ea7470 TCPv6 :: 49667 :: 0 LISTENING 1308 svchost.exe 2026-09-17 15:58:49.000000 UTC
0xa18c37ea7730 TCPv4 0.0.0.0 49667 0.0.0.0 0 LISTENING 1308 svchost.exe 2026-09-17 15:58:49.000000 UTC
0xa18c37ea7b50 TCPv4 0.0.0.0 49668 0.0.0.0 0 LISTENING 2484 spoolsv.exe 2026-09-17 15:58:51.000000 UTC
0xa18c37ea7b50 TCPv6 :: 49668 :: 0 LISTENING 2484 spoolsv.exe 2026-09-17 15:58:51.000000 UTC
0xa18c37f71a20 TCPv4 192.168.6.133 49688 52.98.143.162 443 CLOSED 6920 SearchApp.exe 2026-09-17 15:59:29.000000 UTC
0xa18c38b06310 TCPv4 0.0.0.0 49664 0.0.0.0 0 LISTENING 844 lsass.exe 2026-09-17 15:58:47.000000 UTC
0xa18c38b06890 TCPv4 0.0.0.0 49665 0.0.0.0 0 LISTENING 716 wininit.exe 2026-09-17 15:58:47.000000 UTC
0xa18c38b069f0 TCPv4 0.0.0.0 49665 0.0.0.0 0 LISTENING 716 wininit.exe 2026-09-17 15:58:47.000000 UTC
0xa18c38b069f0 TCPv6 :: 49665 :: 0 LISTENING 716 wininit.exe 2026-09-17 15:58:47.000000 UTC
0xa18c38b06b50 TCPv4 0.0.0.0 49666 0.0.0.0 0 LISTENING 1356 svchost.exe 2026-09-17 15:58:48.000000 UTC
0xa18c38b06b50 TCPv6 :: 49666 :: 0 LISTENING 1356 svchost.exe 2026-09-17 15:58:48.000000 UTC
0xa18c38b06cb0 TCPv4 0.0.0.0 135 0.0.0.0 0 LISTENING 568 svchost.exe 2026-09-17 15:58:47.000000 UTC
0xa18c38b06cb0 TCPv6 :: 135 :: 0 LISTENING 568 svchost.exe 2026-09-17 15:58:47.000000 UTC
0xa18c38b06e10 TCPv4 0.0.0.0 49666 0.0.0.0 0 LISTENING 1356 svchost.exe 2026-09-17 15:58:48.000000 UTC
0xa18c38b070d0 TCPv4 0.0.0.0 49668 0.0.0.0 0 LISTENING 2484 spoolsv.exe 2026-09-17 15:58:51.000000 UTC
0xa18c38b07a70 TCPv4 0.0.0.0 49664 0.0.0.0 0 LISTENING 844 lsass.exe 2026-09-17 15:58:47.000000 UTC
0xa18c38b07a70 TCPv6 :: 49664 :: 0 LISTENING 844 lsass.exe 2026-09-17 15:58:47.000000 UTC
0xa18c38b07bd0 TCPv4 0.0.0.0 135 0.0.0.0 0 LISTENING 568 svchost.exe 2026-09-17 15:58:47.000000 UTC
0xa18c3c3cd20 UDPv4 0.0.0.0 0 * 0 2088 svchost.exe 2026-09-17 15:58:51.000000 UTC
0xa18c3c3cd20 UDPv6 :: 0 * 0 2088 svchost.exe 2026-09-17 15:58:51.000000 UTC
0xa18c3c6d8c0 UDPv4 0.0.0.0 5353 * 0 2088 svchost.exe 2026-09-17 15:58:51.000000 UTC
0xa18c3c6d8c0 UDPv6 :: 5353 * 0 2088 svchost.exe 2026-09-17 15:58:51.000000 UTC
0xa18c3c6d9630 UDPv4 0.0.0.0 5353 * 0 2088 svchost.exe 2026-09-17 15:58:51.000000 UTC
0xa18c3c7eddb0 UDPv4 0.0.0.0 0 * 0 2208 svchost.exe 2026-09-17 16:33:38.000000 UTC
0xa18c3c913d60 UDPv4 0.0.0.0 65367 * 0 2512 svchost.exe 2026-09-17 15:58:52.000000 UTC
0xa18c3c913d60 UDPv6 :: 65367 * 0 2512 svchost.exe 2026-09-17 15:58:52.000000 UTC
0xa18c3c9143a0 UDPv4 0.0.0.0 65366 * 0 2512 svchost.exe 2026-09-17 15:58:52.000000 UTC
0xa18c3c92c0e0 UDPv4 127.0.0.1 65368 * 0 2936 svchost.exe 2026-09-17 15:58:54.000000 UTC
0xa18c3cb78b50 TCPv4 0.0.0.0 49669 0.0.0.0 0 LISTENING 836 services.exe 2026-09-17 15:58:54.000000 UTC
0xa18c3cb78b50 TCPv6 :: 49669 :: 0 LISTENING 836 services.exe 2026-09-17 15:58:54.000000 UTC
0xa18c3cb78cb0 TCPv4 0.0.0.0 445 0.0.0.0 0 LISTENING 4 System 2026-09-17 15:58:56.000000 UTC
0xa18c3cb78cb0 TCPv6 :: 445 :: 0 LISTENING 4 System 2026-09-17 15:58:56.000000 UTC
0xa18c3cb790d0 TCPv4 0.0.0.0 49669 0.0.0.0 0 LISTENING 836 services.exe 2026-09-17 15:58:54.000000 UTC
0xa18c3cb79230 TCPv4 0.0.0.0 5040 0.0.0.0 0 LISTENING 5616 svchost.exe 2026-09-17 15:59:09.000000 UTC
0xa18c3cfd7260 TCPv4 192.168.6.133 49912 150.171.27.12 443 CLOSED 8644 backgroundTask 2026-09-17 16:33:31.000000 UTC
0xa18c3d09d080 UDPv4 0.0.0.0 0 * 0 2208 svchost.exe 2026-09-17 16:33:38.000000 UTC
0xa18c3d09d080 UDPv6 :: 0 * 0 2208 svchost.exe 2026-09-17 16:33:38.000000 UTC
0xa18c3d09f150 UDPv4 0.0.0.0 0 * 0 2208 svchost.exe 2026-09-17 16:33:38.000000 UTC
0xa18c3d206730 UDPv4 192.168.6.133 1900 * 0 3216 svchost.exe 2026-09-17 15:58:59.000000 UTC
0xa18c3d218390 UDPv4 0.0.0.0 3702 * 0 2888 dasHost.exe 2026-09-17 15:59:00.000000 UTC
0xa18c3d218390 UDPv6 :: 3702 * 0 2888 dasHost.exe 2026-09-17 15:59:00.000000 UTC
```

Figure 30: Volatility windows.netscan output showing network objects, including the SMB listener on TCP 445.

```
(hemanth@HemanthKali)-[~/volatility3]
$ python3 vol.py -f "/mnt/hgfs/VMShare-2/Windows 10 x64-80e1c10a.vmem" windows.filescan | grep -Ei
0xa18c3d8703c0\Windows\System32\PerceptionSimulation\en-US\PerceptionSimulationService.exe.mui
0xa18c3d871680 \Windows\System32\PerceptionSimulation\PerceptionSimulationService.exe
Exception ignored in: <function MagicDetect.__del__ at 0x7fb2a779e020>
Traceback (most recent call last):
  File "/usr/lib/python3/dist-packages/magic/compat.py", line 299, in __del__
  File "/usr/lib/python3/dist-packages/magic/compat.py", line 126, in close
TypeError: 'NoneType' object is not callable
```

Figure 31: Volatility filescan search showing no direct recovery of the staged or. locked lab artefacts.

9.5 Reconstructed Incident Timeline

The evidence may be presented on one single practical timeline. This can be helpful as each individual tool can view a different aspect of the exercise. Wazuh is best when it comes to firewall and authentication events, Sysmon adds process information, Wireshark records the network traffic, filesystems provide artefacts for staging and encryption, and Volatility records the endpoint state at the end of the exercise.

#	Stage	Activity	Evidence	ATT&CK
---	-------	----------	----------	--------

#	Stage	Activity	Evidence	ATT&CK
1	Reconnaissance	Kali SYN scan against 192.168.6.133	Wireshark, Event 5157, Wazuh 100201	T1046
2	Credential attempt	Deliberate failed SMB login for labuser	Event 4625 / Wazuh	T1078 context
3	Credentialed access	Successful SMB Logon Type 3	Event 4624 / Wazuh / smbclient	T1078.003
4	Discovery	Manual and Atomic account/system discovery	Sysmon Event 1, Atomic output	T1087.001 + related discovery
5	Staging	Synthetic files compressed into Healthcare_Test_Archive.zip	Filesystem and archive hash	T1074
6	Exfiltration	Archive transferred to Kali on TCP/9001	Netcat, Wireshark, matching SHA-256	TA0010
7	Impact	Copied synthetic files encrypted to .locked	LabImpactSim, hashes and README	T1486
8	Forensics	Logs, PCAP and memory preserved and analysed	EVTX, PCAP, SHA-256, Volatility	Post-incident analysis

Table 11: Reconstructed Section B incident timeline.

9.6 Forensic Interpretation and Limitations

The forensic results corroborate the simulated scenario but it is also clear where evidence can go. It was easier to show that the network sessions were shorter in length in PCAP than would be in a later memory snapshot. The objects in files created before were not always guaranteed to be recoverable via filescan. The first raw memory acquisition that was not usable was replaced with a VMware memory source. These are real forensic problems: The quality of

the evidence is dependent on the timing of evidence collection, the method of evidence collection and whether durable artifacts from the activity were created.

There's a definitive distinction between simulation evidence and the actual Change Healthcare incident, as well. No lab ip addresses, port 9001, synthetic filenames, AES script or labuser account are historical IOCs. What is special about them is that they result in behaviour that is visible and can be studied. The mapping of the case-study is thus behavioural and not that the production intrusion used the same commands or infrastructure.

10.0 Incident Response Analysis

10.1 NIST Incident Response Approach

The analysis of the response is based on NIST SP 800-61 Rev. 3, which incorporates incident response into the broader framework of the CSF 2.0 risk-management model. The NIST current perspective focuses on preparation (Govern, Identify and Protect), and an incident-response lifecycle (NIST, 2025) is active: Detect, Respond and Recover with a thrust on continual improvement. To facilitate easy reading, the practical results are still presented in the context of the familiar operational activities of preparation, detection, containment, eradication, recovery and post-incident improvement.

10.2 Preparation

Preparation in this lab entailed the construction of the monitoring prior to the beginning of the attack simulation. Then Wazuh, Sysmon, Windows Firewall auditing and Wireshark were configured. The victim IP address and attacker IP address were determined, synthetic data was created and the evidence source to be expected at each step was identified. This would have made the Nmap activity much harder to be useful as a SIEM alert in later stages if it wasn't for the fact that the Event 5157 collection was done, and the custom Wazuh correlation rule.

This would involve phishing-resistant MFA, accurate asset and identity inventories, protected backups, incident-response authority, contact lists, forensic collection procedures and exercises, as well in an enterprise environment. The development of acquired or legacy systems must be part of those preparations and not be placed outside the normal security baseline as shown by the Change Healthcare case.

10.3 Detection and Analysis

The lab shows that the detection is enhanced with the addition of weak signals. If there is one connection blocked, it may be background noise. A failed attempt to log in could be a type mistake. If these are repeated to the service and a network logon is successful, followed by account discovery, creation of an archive and some odd outgoing behavior, that's a much bigger deal. A piece of that chain was each provided by Wazuh, Windows events, Sysmon, Wireshark and file evidence.

Even though the telemetry information is not public, Change Healthcare follows the same rule. There are opportunities to act before mass encryption – such as identity context, privilege changes, sensitive-data access or transfer outwards. So the detection strategy should not be focused on a 'ransomware alert' but rather on behaviour chains.

10.4 Containment

The first containment measures would be to isolate the affected host, disable or reset compromised accounts, block known malicious network paths and securing identity and backup infrastructure from this lab sequence if it was a true ransomware intrusion. Volatile evidence should be recorded, if possible, prior to unnecessary changes. The goal is to prevent the attacker from progressing from one compromised endpoint to hypervisors or backup systems – and that's where segmentation is important.

A business cost is also associated with containment. Disconnecting systems to protect the wider environment caused by Change Healthcare was a factor in service disruption. Incident response requires authority and business involvement: sometimes the most secure technical response will have immediate operational implications that need to be planned ahead of time.

10.5 Eradication

Eradication would eliminate attacker persistence and tooling, eliminate unauthorized sessions, rotate exposed credentials and keys, and patch the initial weakness and verify privileged identities. If Active Directory access had taken place, the domain controllers and administrative accounts would have been a special focus. There was no actual malware or persistence in the lab and eradication consisted of preserving evidence first, and then removing temporary test artefacts as necessary.

10.6 Recovery

Recovery should include restoration from known good sources, validation prior to reconnection and ongoing monitoring following restoration. The impact simulation left the original files in C:\LabData, and encrypted only copies, allowing for a simple example of clean-data recovery. The equal control in a real business is a proven backup approach that does not rely on the internet and is not modifiable, plus clean build processes and identity recovery.

10.7 Post-Incident Activity

Post incident work: translates evidence into improvement. The time line should be finalized, root causes and detection gaps should be documented, response decision should be reviewed and the exercise should be repeated after changes are made, tuning of Wazuh rules should be documented. The key areas of inconsistency within this lab were around the archive creation and out-of-the-box transfer and file-encryption behaviour. They could be forensically identified but customised SIEM correlation was not available for all stages. Those gaps are tangible and become follow-up actions instead of being obscured.

10.8 Data Access Rights and Evidence Handling

Incident responders will not have access to all systems or records. Access to be given on a role basis; on an authorisation basis; and in terms of minimum data required for the investigation. This is particularly significant in a healthcare setting as evidence can include PHI, PII, or payment information. Investigators should maintain separate evidence sites and make it a practice to document evidence handlers, restrict access to the forensic dataset and refrain from opening up any other patient information just because they could in principle.

The same applies when it comes to containment. Actions including disabling an account, isolating a server or obtaining memory should be taken by those who have the authority to do so. NIST SP 800-61 Rev. 3 emphasizes the importance of roles, responsibilities and authorities in incident response policy and procedures (NIST, 2025). All systems and data used in the lab were owned for testing purposes, which was easy to authorize a formal approval and chain of custody process would be required for a production investigation.

10.9 Ethical Responsibilities of IT Professionals

The security professional's ethical duty is to ensure confidentiality in an incident investigation. Evidence shouldn't be shared beyond its immediate purpose, credentials should not be included in reports, and sensitive screenshots should be checked prior to sharing or submission. The Wazuh screenshot, which included the administrative password, was not included, on purpose, in this report. The same decision should be made with regard to patient information, tokens, private keys and other secrets.

Test must remain on scope. The techniques in this assignment were used only on isolated virtual machines and synthetic data. Running Nmap, credential tests, exfiltration tools or encryption scripts against systems without permission would change the exercise from authorised security testing into potentially harmful activity. Accurate reporting is part of the ethical duty as well: uncertain findings are labelled as uncertain rather than exaggerated to make the investigation look more dramatic.

10.10 Relevant Policies and Standards

A real organisation should support the technical response with documented policy. At minimum, this includes an incident-response policy, access-control and privileged-access policy, logging and monitoring policy, backup and recovery policy, acceptable-use rules, evidence-handling procedures and a breach-notification process. For healthcare organisations, privacy and security requirements around PHI must also be built into the response process rather than handled as a separate afterthought.

NIST SP 800-61 Rev. 3 provides the main incident-response framework used here. NIST CSF 2.0 can be used to connect incident response with governance and risk management. MITRE ATT&CK provides the behavioural language for detection and testing, while organisation-specific policies define who is allowed to isolate systems, access sensitive logs, acquire forensic images or approve recovery. The playbook in the next section converts those higher-level requirements into practical steps.

IR Stage	Laboratory Evidence	Enterprise Application
----------	---------------------	------------------------

IR Stage	Laboratory Evidence	Enterprise Application
Preparation	Isolated lab, Wazuh, Sysmon, Windows auditing, Wireshark and evidence plan.	MFA, asset inventory, logging baselines, tested backups and response authority.
Detection & Analysis	T1046 correlation, 4625/4624 analysis, Sysmon and PCAP correlation.	Identity analytics, EDR/SIEM correlation, DLP and anomaly detection.
Containment	Simulation boundaries and evidence preservation.	Host isolation, account disable/reset, segmentation and network blocking.
Eradication	No real malware; temporary artefacts removed after preservation.	Remove persistence/tools, rotate secrets, patch and validate identity infrastructure.
Recovery	Original LabData preserved and integrity checked.	Restore from clean backups, reconnect in stages and monitor closely.
Post-Incident	Timeline, forensic review, detection-gap analysis and rule improvement.	Lessons learned, control validation, playbook updates and governance review.

Table 12: NIST-aligned incident response interpretation of the practical findings.

11.0 Cyber Incident Response Playbook and Preventive Controls

11.1 Operational Ransomware Playbook

The playbook below is designed for a ransomware scenario where credential abuse, discovery, data movement and encryption may all be involved. The order is intentional. Evidence should be preserved while the organisation is still containing the attack, and recovery should not begin until the team has enough confidence that attacker access has been removed. Depending on business impact, some steps will overlap in practice.

Step	Required Action	Owner	Primary Evidence / Control
1. Detect	Confirm alert source, host, user, process and network context; correlate repeated events.	SOC Analyst	Wazuh, EDR/Sysmon, Windows Security logs
2. Triage	Decide whether activity is scanning, credential abuse, discovery, exfiltration or impact.	SOC Analyst / IR Lead	SIEM timeline, PCAP and identity logs
3. Contain	Isolate affected hosts; disable compromised accounts; block malicious traffic; protect backups and identity systems.	IR Lead / Network / IAM	EDR isolation, firewall and IAM controls
4. Preserve	Export logs, capture memory where practical, retain PCAP and hash evidence.	Forensic Analyst	EVTX, VMEM, PCAP and SHA-256
5. Investigate	Reconstruct access, privilege, discovery, staging, movement and impact.	Forensic Analyst / CTI	Wazuh, Sysmon, Volatility and file evidence
6. Eradicate	Remove attacker persistence/tools; rotate credentials and keys; patch weaknesses.	System / Security Admin	EDR, IAM, patching and configuration review
7. Recover	Restore from known-good backups; validate systems; reconnect in controlled phases.	IT Operations / Business Owners	Backup platform and validation checklist
8. Improve	Run lessons learned; tune detections; update playbook; retest controls.	Security Management / SOC	Post-incident review and Atomic Red Team

Table 13: Ransomware incident response playbook.

11.2 Detection and Escalation Criteria

Escalation should be based on combinations of behaviour. Repeated firewall blocks from one source across many ports, a successful remote logon after failures, a new device using a privileged account, rapid account or share discovery, archive creation around sensitive data, unusual outbound connections, and rapid file modification are all useful examples. Mass encryption should trigger immediate containment, but the preferred outcome is to recognise the sequence before the impact stage begins.

11.3 Zero Trust Application

The valid-account stage illustrates the basic Zero Trust idea that a correct password is not enough. Access decisions should consider identity, MFA strength, device health, location or network context, requested resource, privilege level and behaviour. For high-value external access, phishing-resistant MFA and conditional access would sharply reduce the usefulness of stolen credentials. Device compliance checks would stop an unmanaged endpoint receiving the same trust as a known corporate device.

Micro-segmentation is the second major control. In the lab, SMB was opened because it was needed for the test. In an enterprise, TCP 445 and administrative protocols should only be available where there is a business requirement. Identity infrastructure, sensitive data, hypervisors and backups should sit behind separate control boundaries. Monitoring then needs to connect identity, endpoint and network data so that a valid account behaving abnormally is treated as suspicious.

11.4 Preventive and Detective Control Recommendations

Control	Rationale	Priority
Phishing-resistant MFA and conditional access	Directly reduces stolen-credential value and addresses the control gap at the start of the Change Healthcare intrusion.	Immediate
Privileged access management and least privilege	Limits privilege expansion and access to identity infrastructure and sensitive information.	Immediate

Control	Rationale	Priority
Network segmentation and SMB restriction	Reduces lateral movement and unnecessary exposure of remote services.	High
Centralised Windows/Sysmon logging	Preserves authentication and process telemetry for earlier investigation.	High
Behaviour-based SIEM correlation	Connects scanning, login, discovery, staging and outbound-transfer indicators.	High
PowerShell and script monitoring	Improves visibility into administrative tools that can be abused during hands-on-keyboard activity.	High
DLP / egress monitoring	Detects unusual archive creation, bulk access and outbound movement before encryption.	High
Immutable / offline backups with restore testing	Reduces availability impact from T1486 and supports trusted recovery.	Immediate
Forensic readiness	Ensures volatile evidence, PCAP and logs can be preserved without improvisation.	Medium
Continuous control validation	Atomic Red Team and safe simulations confirm that expected telemetry and alerts are actually produced.	Ongoing

Table 14: Recommended preventive and detective controls derived from the case study and practical findings.

11.5 Relationship to the Change Healthcare Case

The practical reinforces the main Section A finding: the best defensive opportunity is before encryption. In the real incident, compromised credentials worked against a legacy remote-access service without MFA, data was exfiltrated before ransomware deployment, and the destructive stage was detected only after the attacker had already achieved several objectives. In the lab, the equivalent early stages produced visible firewall, authentication, process and network evidence before the file-encryption simulation took place.

The exercise also reinforces the need to protect both confidentiality and availability. Backups may be useful to restore an encrypted system, but they are not useful to restore data if it has been stolen. Egress monitoring can help prevent data loss, but will not be sufficient if systems are still encrypted when a resilient backup is required. These must all work together. These have to work hand in hand.

12.0 Combined Conclusion

12.1 Key Findings

In the case of Change Healthcare, the credential-based compromise escalated from a local incident to a nationwide healthcare disruption because the company is located at the epicentre of vital shared services within the healthcare industry. Section A was an established sequence that compromised credentials on a legacy Citrix portal without MFA, privilege escalation was done, PHI was exfiltrated and ALPHV/BlackCat ransomware encrypted Windows and ESXi systems. There are numerous effects that reach out from technical operations, provider cash flow, privacy duties, regulatory oversight and organisational trust.

In section B, those lessons were taken and applied in a controlled VMware testbed. Results of the reconnaissance were packet, firewall and SIEM evidence; failed and successful network-logon events were the products of the SMB access; manual and Atomic discovery produced endpoint telemetry; the staging and transfer of synthetic files demonstrated their matching hashes; and file-encryption impact was confirmed only against copies. In subsequent investigations, the need for multiple sources of evidence became apparent. Wazuh, Sysmon, Windows logs, Wireshark, hashes and Volatility each had their answer to a part of the investigation.

12.2 Assumptions

All the analysis assumes that the information contained in the public statements issued by UHG, congressional records, HHS, and the joint federal advisory properly represents what they claim happened with the portions of the incident they report. If the specific technique is not common, the report deliberately does not go any further than the tactic level. While the selected lab behaviours are used as examples, it is assumed that they are reasonable proxies for the same

concepts from the ATT&CK framework as the real attacker used tools, commands, protocols or infrastructure.

12.3 Limitations

Several limitations remain. Not all commands, log sources or post exploitation methods are disclosed in the Public Change Healthcare report. Lateral movement and deployment of ransomware on large scale are not reproduced in the lab, using only one Windows endpoint, instead of an entire enterprise Active Directory setting. The exfiltration step only relies on TCP port 9001 as a safe demonstration and should not be interpreted as the real incident. Some short-lived network and file artefacts were missing since the exercise was captured towards the end. Lastly, the endpoint telemetry for the encryption portion was reduced as C:\LabImpactSim was not monitored by Sysmon.

12.4 Challenges Encountered

Several rounds of troubleshooting were required in the practical. I had some problems installing Ubuntu 24.04, but I rebuilt the Wazuh server on Ubuntu 22.04.5 instead. VMware networking had to be fixed to enable the hosts to communicate. The configuration was narrowed down to generate only the most benign ProcessAccess noise for sysmon. Event ID 5157 was originally not collected by Wazuh and needed to be activated before being able to use the scan correlation. The problems with memory collection were the first WinPmem image was incomplete/inusable for Volatility, and thus the VMware .vmem/.vmss approach was used. I'm not sure if these were frustrating at the time, but it was really helpful to have them tested instead of being forgotten in the process of writing the final evidence.

12.5 Recommendations

The top recommendation is to render stolen credentials far less valuable. Consider implementing phishing-resistant MFA, conditional access, device trust and privileged-access management for external services and admin services. It is important to integrate legacy and acquired systems into a common baseline without delay, rather than taking them as an exception. Network segmentation should limit access to the SMB, remote administration, hypervisor access and backup paths. Detection should be based on identity, endpoint and network behaviour and

DLP and egress monitoring should seek to identify staging and unusual outbound activity prior to encryption starting.

Ransomware resilience also demands that you have tested immutable or offline backups, that you have defined your priorities for recovery, that you are prepared for forensics and that you have an incident-response playbook that you have actually tested. The lab demonstrated the expected evidence only in the presence of pre-programmed logging and collection. It is important to test coverage, and not take it for granted.

12.6 Further Enhancements

Another possible addition in a future version of the lab would be a small Active Directory domain that would allow a more realistic test of domain-account discovery, privilege changes and segmentation. The rules for adding Wazuh for archive creation, abnormal outbound transfer, suspicious PowerShell patterns, and rapid file modification could be added. To test lateral movement safely a second endpoint could be added. Memory and PCAP capture could also be enabled nearer to each attack stage to retain short-lived artefacts. If the same Atomic tests were repeated after the tuning, a simple before and after measurement of detection could be achieved.

12.7 Final Conclusion

The overall takeaway from both parts is that an organization is likely to have either been successful or unsuccessful in securing ransomware protection before files are hit by ransomware. When it comes to credential abuse, privilege expansion and data theft, Change Healthcare had a window that needed to be closed, and the lab demonstrated that detectable evidence can be generated during the same windows of opportunity if it's the right type of telemetry. A robust response will, therefore, have identity security, segmentation, behaviour detection, secure backups, forensic readiness and response authority. None of them can take the place of another product. Whether or not the controls are working together is the key that they are working in time to prevent a legitimate account from becoming a threat to data theft and impact.

13.0 References

- American Hospital Association. (2024, March 15). AHA survey: Change Healthcare cyberattack significantly disrupts patient care, hospitals' finances. <https://www.aha.org/2024-03-15-aha-survey-change-healthcare-cyberattack-significantly-disrupts-patient-care-hospitals-finances>
- American Medical Association. (2024, April 10). Physicians struggle to keep practices afloat after Change cyberattack. <https://www.ama-assn.org/press-center/ama-press-releases/physicians-struggle-keep-practices-afloat-after-change-cyberattack>
- Asia Pacific University of Technology & Innovation. (2026a). Cyber threat intelligence [Lecture slides]. CT114-3-3-VCS Advanced Cyber Security.
- Asia Pacific University of Technology & Innovation. (2026b). Cybercrime profiling [Lecture slides]. CT114-3-3-VCS Advanced Cyber Security.
- Asia Pacific University of Technology & Innovation. (2026c). Understanding attack DNA: MITRE ATT&CK framework [Lecture slides]. CT114-3-3-VCS Advanced Cyber Security.
- Cybersecurity and Infrastructure Security Agency, Federal Bureau of Investigation, & U.S. Department of Health and Human Services. (2024, February 27). #StopRansomware: ALPHV Blackcat (AA23-353A). https://www.cisa.gov/sites/default/files/2024-03/aa23-353a-stopransomware-alphv-blackcat-update_2.pdf
- Microsoft. (2026). Sysmon - Sysinternals. Microsoft Learn. <https://learn.microsoft.com/sysinternals/downloads/sysmon>
- MITRE ATT&CK. (2025, October 21). BlackCat (S1068). <https://attack.mitre.org/software/S1068/>
- National Institute of Standards and Technology. (2025). Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile (NIST SP 800-61 Rev. 3). <https://doi.org/10.6028/NIST.SP.800-61r3>
- Nmap Project. (2026). Nmap: Network Mapper. <https://nmap.org/>

Red Canary. (2026). Atomic Red Team documentation: Getting started.

<https://www.atomicredteam.io/docs/atomic-red-team>

U.S. Department of Health and Human Services, Office for Civil Rights. (2025). Change Healthcare cybersecurity incident frequently asked questions.

<https://www.hhs.gov/hipaa/for-professionals/special-topics/change-healthcare-cybersecurity-incident-frequently-asked-questions/index.html>

U.S. Department of Justice. (2023, December 19). Justice Department disrupts prolific ALPHV/Blackcat ransomware variant. <https://www.justice.gov/usao-sdfl/pr/justice-department-disrupts-prolific-alphvblackcat-ransomware-variant>

U.S. House Committee on Energy and Commerce. (2024, May 3). What we learned: Change Healthcare cyber attack. <https://energycommerce.house.gov/posts/what-we-learned-change-healthcare-cyber-attack>

U.S. Senate Committee on Finance. (2024, May 1). Wyden hearing statement on Change Healthcare cyberattack and UnitedHealth Group's response. <https://www.finance.senate.gov/chairmans-news/wyden-hearing-statement-on-change-healthcare-cyberattack-and-unitedhealth-groups-response>

U.S. Senate Committee on Finance. (2024). Responses to questions for the record for Andrew Witty: Hacking America's health care—Assessing the Change Healthcare cyber attack and what's next. https://www.finance.senate.gov/imo/media/doc/responses_for_questions_for_the_record_to_andrew_witty.pdf

UnitedHealth Group. (2024a, April 22). UnitedHealth Group updates on Change Healthcare cyberattack. <https://www.unitedhealthgroup.com/newsroom/2024/2024-04-22-uhg-updates-on-change-healthcare-cyberattack.html>

UnitedHealth Group. (2024b, March 7). UnitedHealth Group update on Change Healthcare cyberattack. <https://www.unitedhealthgroup.com/newsroom/2024/2024-03-07-uhg-update-change-healthcare-cyberattack.html>

UnitedHealth Group. (2025). 2024 annual report (Form 10-K).

<https://www.unitedhealthgroup.com/content/dam/UHG/PDF/investors/2024/UNH-Q4-2024-Form-10-K.pdf>

Volatility Foundation. (2025, May 16). Announcing the official parity release of Volatility 3.

<https://volatilityfoundation.org/announcing-the-official-parity-release-of-volatility-3/>

Wazuh. (2026). Getting started with Wazuh. <https://documentation.wazuh.com/current/getting-started/index.html>

Wireshark Foundation. (2026). About Wireshark. <https://www.wireshark.org/about>

Appendices

Appendix A: Custom Wazuh Detection Rules

The following rules were used to turn individual Windows Firewall Event ID 5157 records into a correlated service-scan alert. The rules 100200 and 100201 detect blocked TCP connections that are received from the same source and destination, and map them into T1046.

```
<group                                name="windows,windows_security,network_scan,">
  <rule                                id="100200"                                level="5">
    <if_sid>60104</if_sid>
    <field                                name="win.system.eventID">^5157$</field>
    <field                                name="win.eventdata.protocol">^6$</field>
    <description>Windows Firewall blocked inbound TCP connection from
$(win.eventdata.sourceAddress) to
$(win.eventdata.destAddress):$(win.eventdata.destPort)</description>
  </rule>

  <rule      id="100201"      level="10"      frequency="6"      timeframe="10">
    <if_matched_sid>100200</if_matched_sid>
    <same_field>win.eventdata.sourceAddress</same_field>
    <same_field>win.eventdata.destAddress</same_field>
    <description>Possible network service scan from
$(win.eventdata.sourceAddress) against
$(win.eventdata.destAddress)</description>
    <mitre><id>T1046</id></mitre>
  </rule>
</group>
```

Appendix B: Selected Practical Commands

Nmap reconnaissance: `sudo nmap -sS -T3 --top-ports 20 192.168.6.133`

Atomic test details: `Invoke-AtomicTest T1087.001 -TestNumbers 9 -ShowDetails`

Atomic execution: `Invoke-AtomicTest T1087.001 -TestNumbers 9`

Windows evidence export: `wevtutil epl Security C:\ForensicEvidence\Security.evtx`

Volatility system identification: `python3 vol.py -f "Windows 10 x64-80e1c10a.vmem" windows.info`

Volatility process list: `python3 vol.py -f "Windows 10 x64-80e1c10a.vmem" windows.pslist`

Volatility network scan: `python3 vol.py -f "Windows 10 x64-80e1c10a.vmem" windows.netscan`

Appendix C: Additional Practical Evidence

```
PS C:\LabTools\Sysmon> Get-WinEvent -LogName "Microsoft-Windows-Sysmon/Operational" -MaxEvents 5 |
>> Select-Object TimeCreated, Id, Message

TimeCreated      Id Message
-----
9/10/2026 11:25:30 PM 3 Network connection detected:...
9/10/2026 11:25:30 PM 3 Network connection detected:...
9/10/2026 11:25:30 PM 13 Registry value set:...
9/10/2026 11:25:30 PM 13 Registry value set:...
9/10/2026 11:25:30 PM 10 Process accessed:...
```

Figure A1: Early Sysmon events confirming endpoint telemetry after installation.

```
PS C:\Windows\system32> Get-WinEvent -FilterHashtable @{
>>   LogName='Microsoft-Windows-Sysmon/Operational'
>>   Id=1
>>   StartTime=(Get-Date).AddMinutes(-15)
>> } | Where-Object {
>>   $_.Message -match 'whoami.exe|hostname.exe'
>> } | Select-Object TimeCreated,Message

TimeCreated      Message
-----
9/17/2026 4:47:02 PM Process Create:...
9/17/2026 4:46:49 PM Process Create:...

PS C:\Windows\system32>
```

Figure A2: Recent Sysmon events used to confirm process telemetry during the practical.

```
(hemanth@HemanthKali)-[~]
$ ls -lh /mnt/hgfs/VMShare-2/memory.raw
-rwxrwxrwx 1 root root 6.5G Sep 17 08:10 /mnt/hgfs/VMShare-2/memory.raw
(hemanth@HemanthKali)-[~]
```

Figure A3: Initial raw memory image exposed through the VMware shared folder before validation.